Security

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS CloudTrail

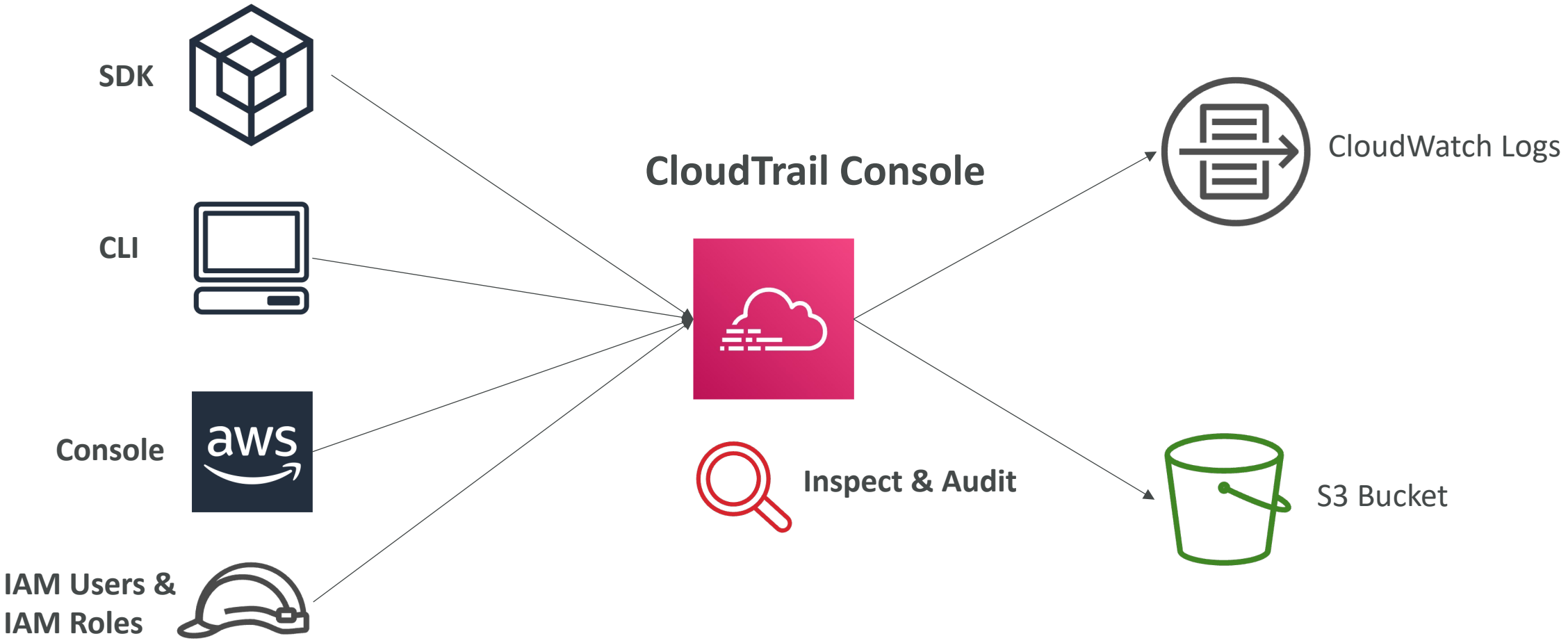


- Provides governance, compliance and audit for your AWS Account
- CloudTrail is enabled by default!
- Get an history of events / API calls made within your AWS Account by:
  - Console
  - SDK
  - CLI
  - AWS Services
- Can put logs from CloudTrail into CloudWatch Logs or S3
- A trail can be applied to All Regions (default) or a single Region.
- If a resource is deleted in AWS, investigate CloudTrail first!

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail Diagram



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail Events



- Management Events:
  - Operations that are performed on resources in your AWS account
  - Examples:
    - Configuring security (IAM **AttachRolePolicy**)
    - Configuring rules for routing data (Amazon EC2 **CreateSubnet**)
    - Setting up logging (AWS CloudTrail **CreateTrail**)
  - By default, trails are configured to log management events.
  - Can separate **Read Events** (that don't modify resources) from **Write Events** (that may modify resources)

- Data Events:
  - By default, data events are not logged (because high volume operations)
  - Amazon S3 object-level activity (ex: **GetObject**, **DeleteObject**, **PutObject**): can separate Read and Write Events
  - AWS Lambda function execution activity (the **Invoke** API)

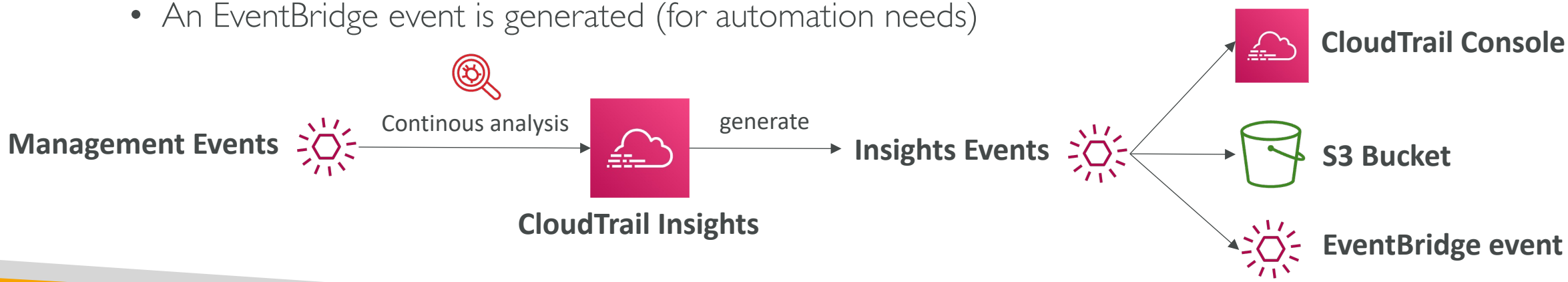
- CloudTrail Insights Events:
  - See next slide ☺

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail Insights

- Enable **CloudTrail Insights to detect unusual activity** in your account:
  - inaccurate resource provisioning
  - hitting service limits
  - Bursts of AWS IAM actions
  - Gaps in periodic maintenance activity
- CloudTrail Insights analyzes normal management events to create a baseline
- And then **continuously analyzes write events to detect unusual patterns**
  - Anomalies appear in the CloudTrail console
  - Event is sent to Amazon S3
  - An EventBridge event is generated (for automation needs)

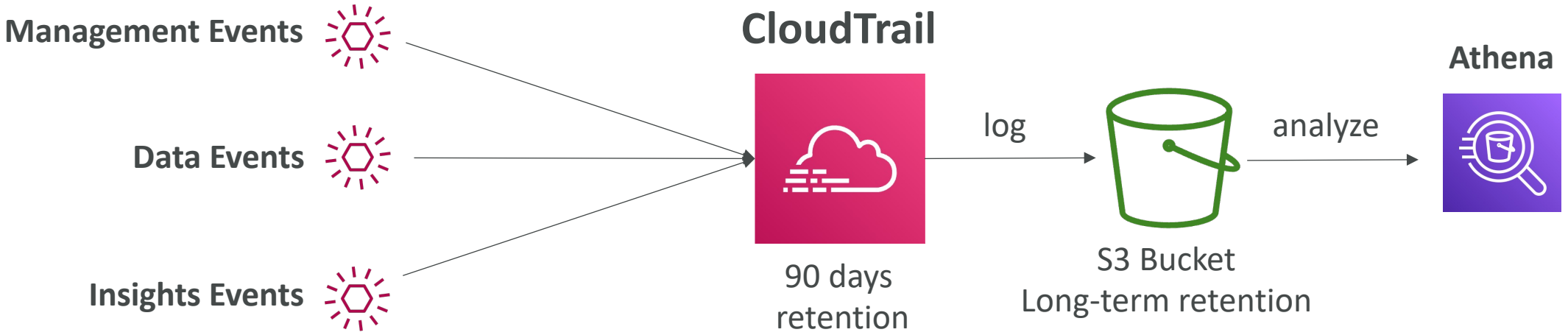


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail Events Retention

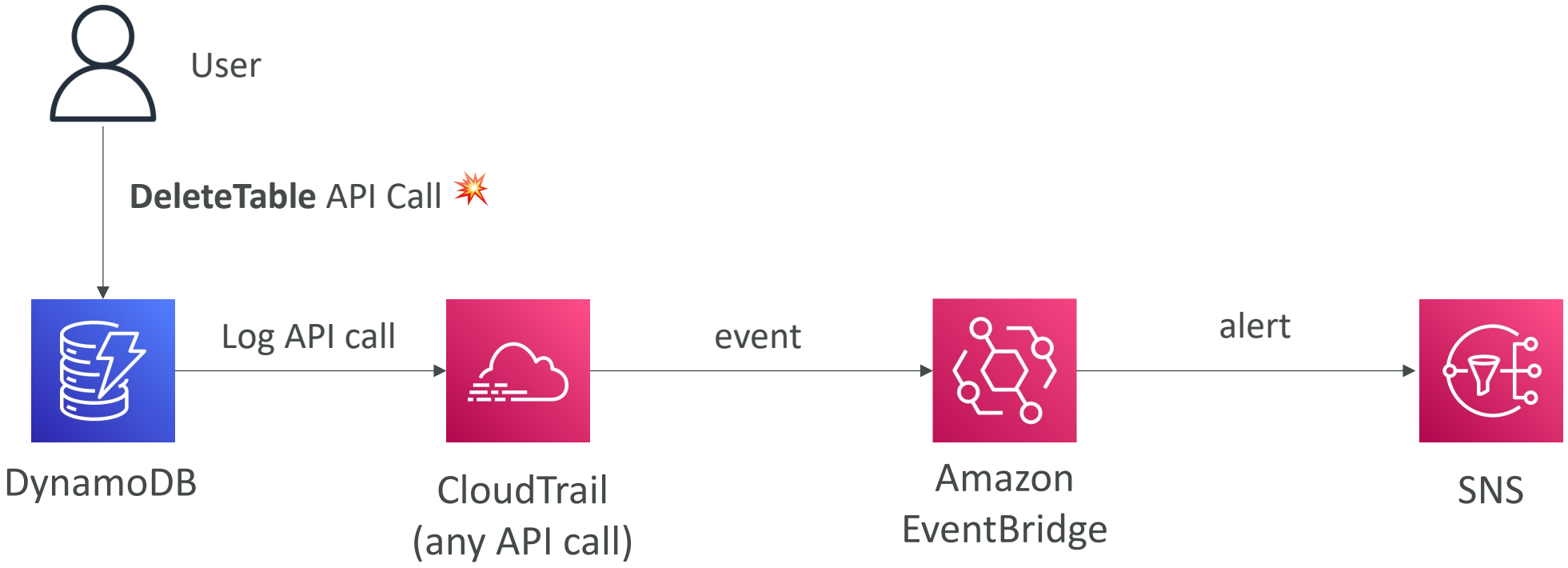
- Events are stored for 90 days in CloudTrail
- To keep events beyond this period, log them to S3 and use Athena



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

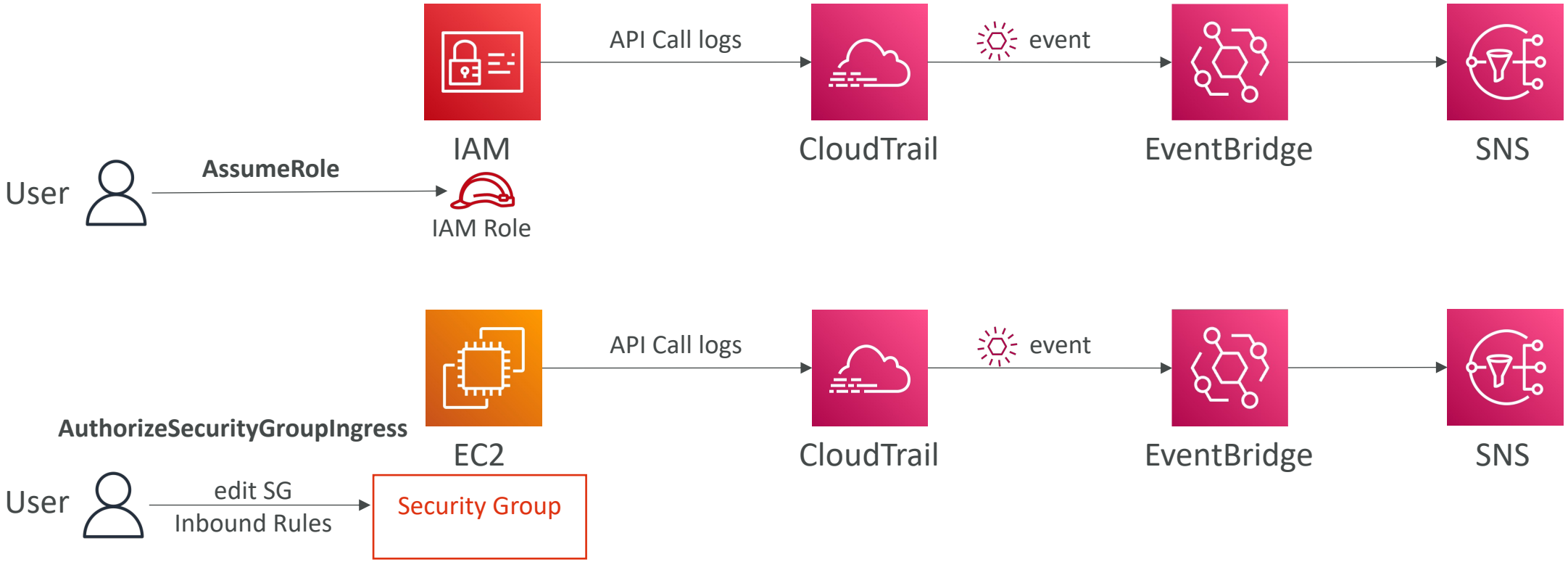
Amazon EventBridge – Intercept API Calls



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

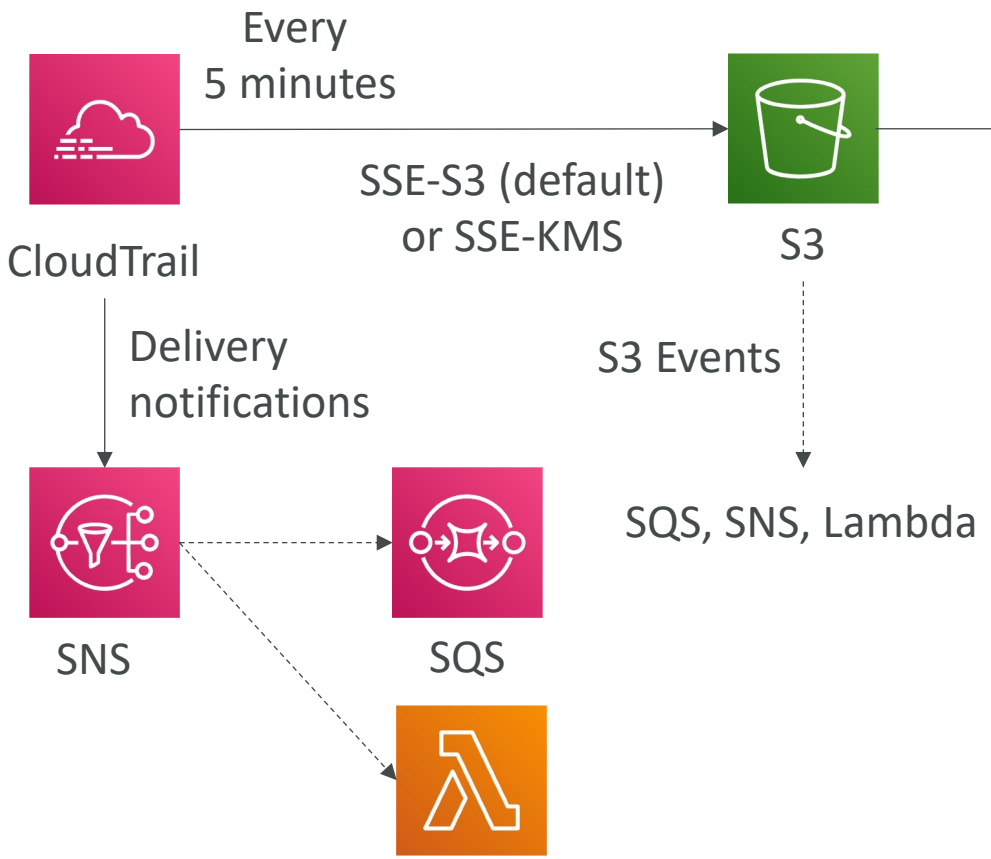
Amazon EventBridge + CloudTrail



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail – Solution Architecture: Delivery to S3



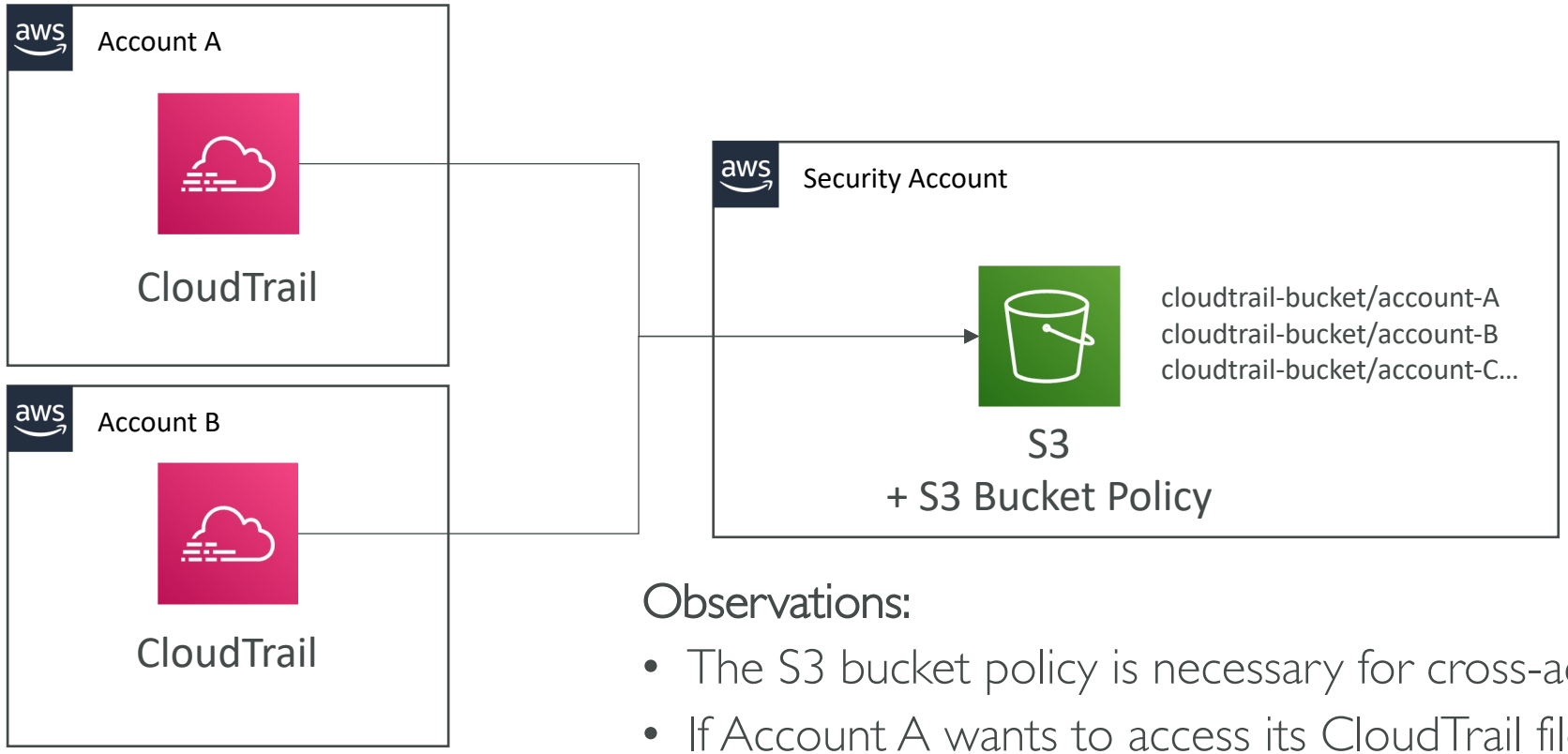
S3 Enhancements:

- Enable Versioning
- MFA Delete Protection
- S3 Lifecycle Policy (S3 IA, Glacier…)
- S3 Object Lock
- SSE-S3 or SSE-KMS encryption
- Feature to perform CloudTrail Log File Integrity validation
(SHA-256 for hashing and signing)

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail - Solution Architecture: Multi Account, Multi Region Logging



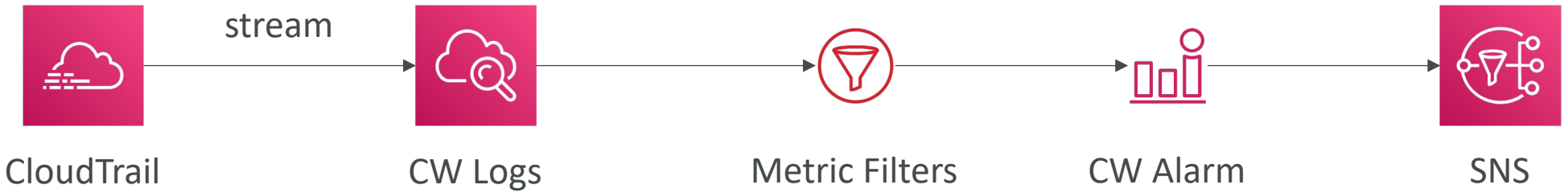
Observations:

- The S3 bucket policy is necessary for cross-account delivery
- If Account A wants to access its CloudTrail files:
  - Option 1: create a cross-account role and assume the role
  - Option 2: edit the bucket policy

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail - Solution Architecture: Alert for API calls



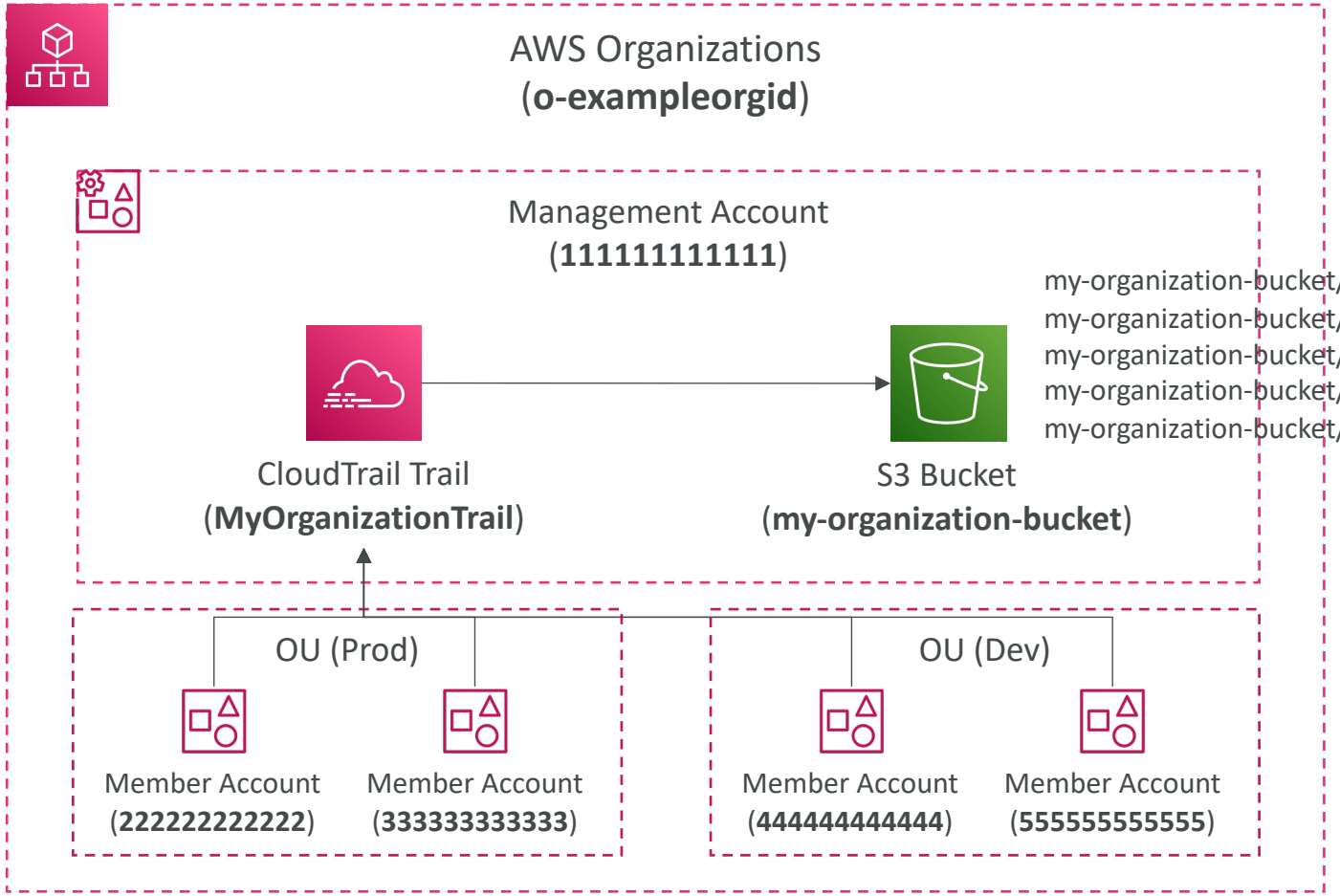
- Log filter metrics can be used to detect a high level of API happening
- Ex: Count occurrences of EC2 **TerminateInstances** API
- Ex: Count of API calls per user
- Ex: Detect high level of Denied API calls

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail – Solution Architecture: Organizational Trail

The Organizational Trail is created in the management account.



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudTrail: How to react to events the fastest?

Overall, CloudTrail may take up to 15 minutes to deliver events

- EventBridge:
  - Can be triggered for any API call in CloudTrail
  - The fastest, most reactive way
- CloudTrail Delivery in CloudWatch Logs:
  - Events are streamed
  - Can perform a metric filter to analyze occurrences and detect anomalies
- CloudTrail Delivery in S3:
  - Events are delivered every 5 minutes
  - Possibility of analyzing logs integrity, deliver cross account, long-term storage

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS KMS (Key Management Service)



- Anytime you hear "encryption" for an AWS service, it's most likely KMS
- Easy way to control access to your data, AWS manages keys for us
- Fully integrated with IAM for authorization
- Seamlessly integrated into:
  - Amazon EBS: encrypt volumes
  - Amazon S3: Server-side encryption of objects
  - Amazon Redshift: encryption of data
  - Amazon RDS: encryption of data
  - Amazon SSM: Parameter store
  - Etc…
- KMS Keys are regional, and can only used in the region they're created in

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

KMS – KMS Key Types

- Symmetric (AES-256 keys)
  - First offering of KMS, single encryption key that is used to Encrypt and Decrypt
  - AWS services that are integrated with KMS use Symmetric KMS keys
  - Necessary for envelope encryption
  - You never get access to the KMS key unencrypted (must call KMS API to use)
- Asymmetric (RSA & ECC key pairs)
  - Public (Encrypt) and Private Key (Decrypt) pair
  - Used for Encrypt/Decrypt, or Sign/Verify operations
  - The public key is downloadable, but you can't access the Private Key unencrypted
  - Use case: encryption outside of AWS by users who can't call the KMS API

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Types of KMS Keys

- Customer Managed Keys
  - Create, manage and use, can enable or disable
  - Possibility of rotation policy (new key generated every year, old key preserved)
  - Can add a Key Policy (resource policy) & audit in CloudTrail
  - Leverage for envelope encryption
- AWS Managed Keys
  - Used by AWS service (aws/s3, aws/ebs, aws/redshift)
  - Managed by AWS (automatically rotated every 1 year)
  - View Key Policy & audit in CloudTrail
- AWS Owned Keys
  - Created and managed by AWS, use by some AWS services to protect your resources
  - Used in multiple AWS accounts, but they are not in your AWS account
  - You can't view, use, track, or audit

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Types of KMS Keys

KMS Key	Customer Managed Key	AWS Managed Key	AWS Owned Key
Can view metadata?	✓	✓	✗
Can manage?	✓	✗	✗
Used only for my AWS account?	✓	✓	✗
Automatic Rotation	90 – 2560 days (365 default)	Required (every 1 year)	Varies
On-demand Rotation	✓	✗	✗

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

KMS Key Material Origin

- Identifies the source of the key material in the KMS key
- Can't be changed after creation

- KMS (AWS_KMS) – default
  - AWS KMS creates and manages the key material in its own key store

- External (EXTERNAL)
  - You import the key material into the KMS key
  - You're responsible for securing and managing this key material outside of AWS

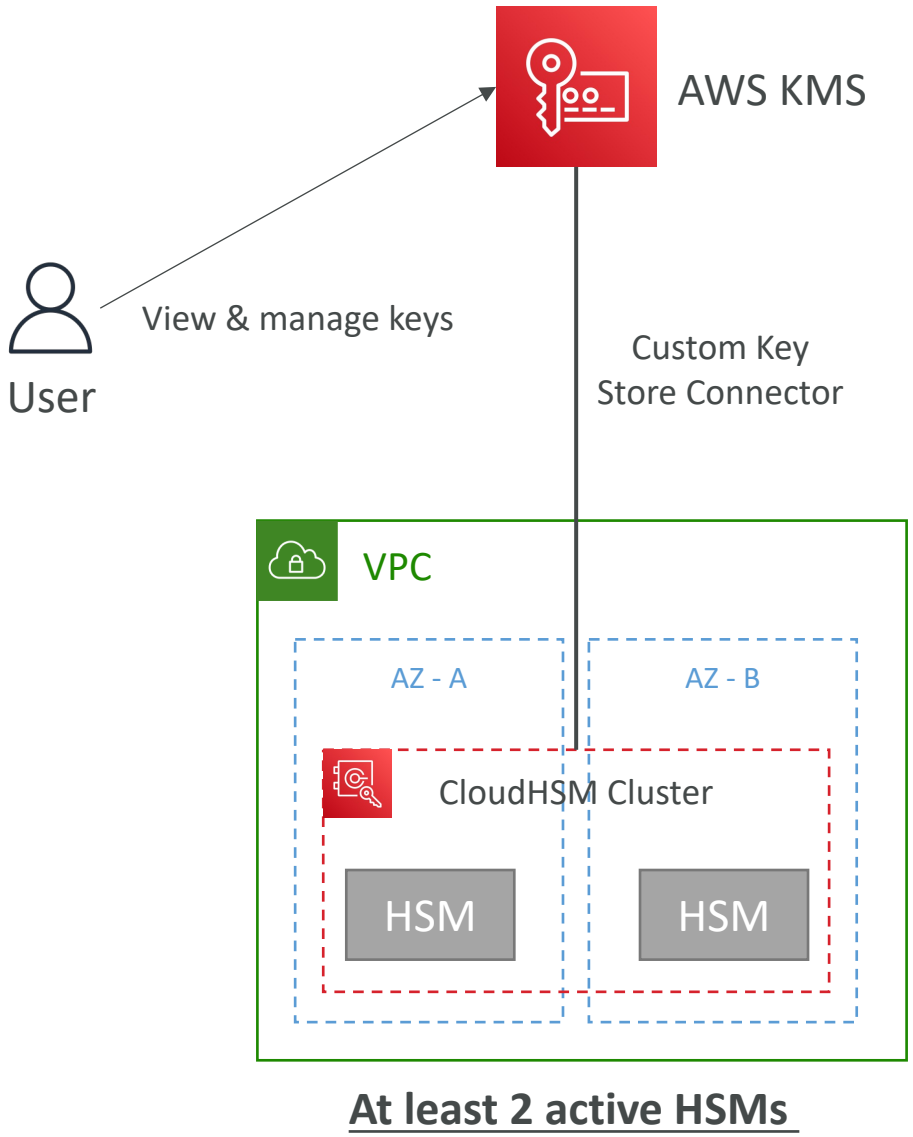
- Custom Key Store (AWS_CLOUDHSM)
  - AWS KMS creates the key material in a custom key store (CloudHSM Cluster)

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

KMS Key Source – Custom Key Store (CloudHSM)

- Integrate KMS with CloudHSM cluster as a Custom Key Store
- Key materials are stored in a CloudHSM cluster that you own and manage
- The cryptographic operations are performed in the HSMs
- Use cases:
  - You need direct control over the HSMs
  - KMS keys needs to be stored in a dedicated HSMs

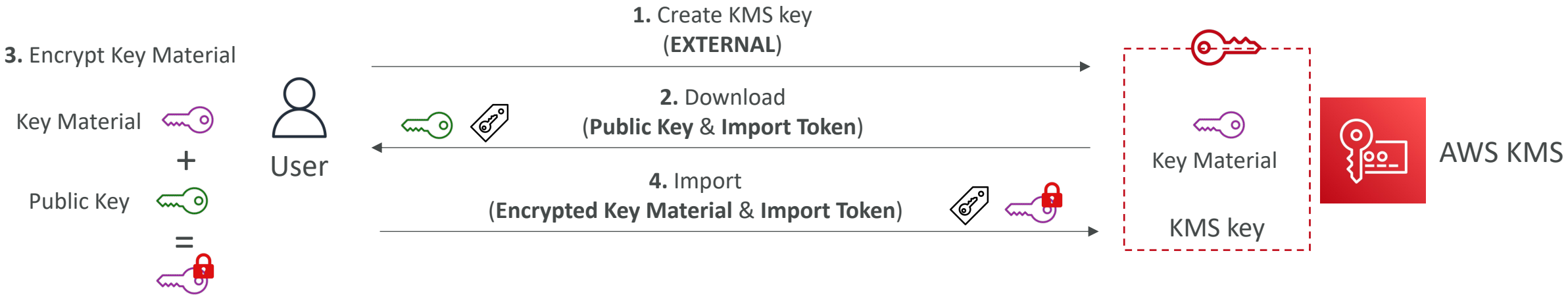


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

KMS Key Source - External

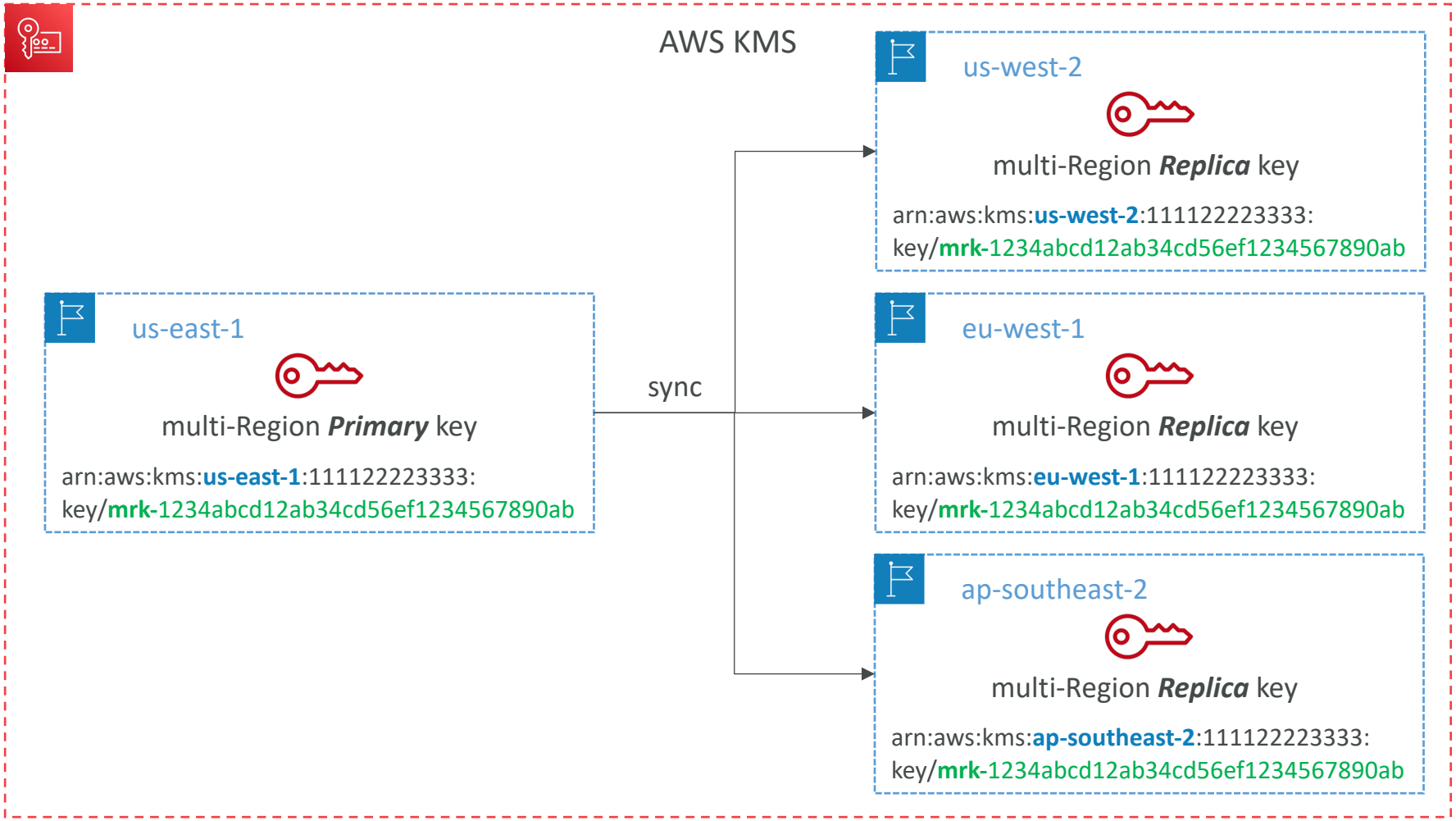
- Import your own key material into KMS key, Bring Your Own Key (BYOK)
- **You're responsible for key material's security, availability, and durability outside of AWS**
- Supports both **Symmetric and Asymmetric** KMS keys
- Can't be used with Custom Key Store (CloudHSM)
- Manually rotate your KMS key (Automatic Key Rotation is NOT supported)



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

KMS Multi-Region Keys



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

KMS Multi-Region Keys



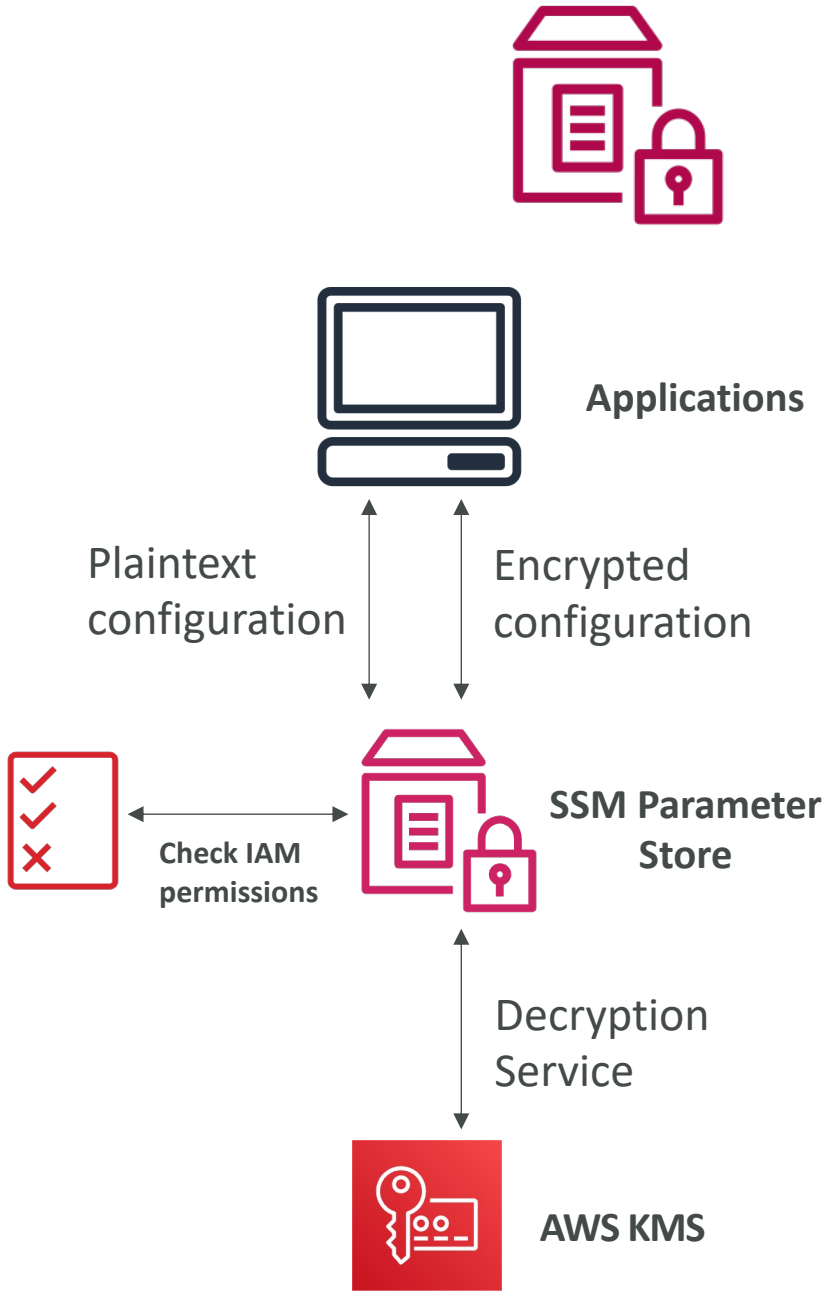
- A set of identical KMS keys in different AWS Regions that can be used interchangeably (~ same KMS key in multiple Regions)
- Encrypt in one Region and decrypt in other Regions (No need to re-encrypt or making cross-Region API calls)
- Multi-Region keys have the same key ID, key material, automatic rotation, …
- KMS Multi-Region are NOT global (Primary + Replicas)
- Each Multi-Region key is managed **independently**
- Only one primary key at a time, can promote replicas into their own primary
- Use cases: Disaster Recovery, Global Data Management (e.g., DynamoDB Global Tables), Active-Active Applications that span multiple Regions, Distributed Signing applications, …

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSM Parameter Store

- Secure storage for configuration and secrets
- Optional Seamless Encryption using KMS
- Serverless, scalable, durable, easy SDK
- Version tracking of configurations / secrets
- Security through IAM
- Notifications with Amazon EventBridge
- Integration with CloudFormation

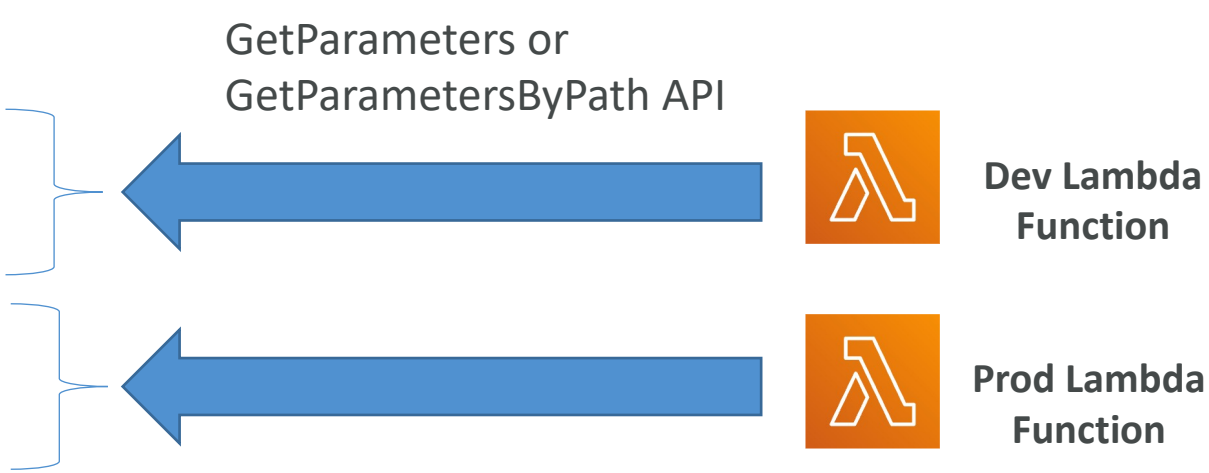


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSM Parameter Store Hierarchy

- /my-department/
  - my-app/
    - dev/
      - db-url
      - db-password
    - prod/
      - db-url
      - db-password
  - other-app/
- /other-department/
- */aws/reference/secretsmanager/secret_ID_in_Secrets_Manager*
- */aws/service/ami-amazon-linux-latest/amzn2-ami-hvm-x86_64-gp2 (public)*



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Standard and advanced parameter tiers

	Standard	Advanced
Total number of parameters allowed (per AWS account and Region)	10,000	100,000
Maximum size of a parameter value	4 KB	8 KB
Parameter policies available	No	Yes
Cost	No additional charge	Charges apply
Storage Pricing	Free	$0.05 per advanced parameter per month

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Parameters Policies (for advanced parameters)

- Allow to assign a TTL to a parameter (expiration date) to force updating or deleting sensitive data such as passwords
- Can assign multiple policies at a time

Expiration (to delete a parameter)

```
{
    "Type":"Expiration",
    "Version":"1.0",
    "Attributes":{
       "Timestamp":"2020-12-02T21:34:33.000Z"
    }
}
```

ExpirationNotification (EventBridge)

```
{
    "Type":"ExpirationNotification",
    "Version":"1.0",
    "Attributes":{
       "Before":"15",
       "Unit":"Days"
    }
}
```

NoChangeNotification (EventBridge)

```
{
    "Type":"NoChangeNotification",
    "Version":"1.0",
    "Attributes":{
       "After":"20",
       "Unit":"Days"
    }
}
```

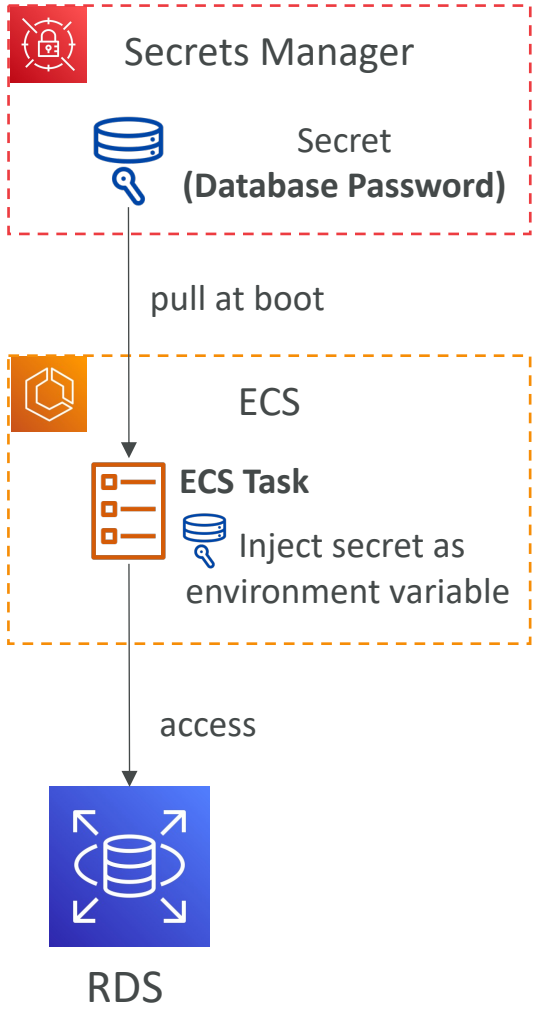
© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Secrets Manager



- Meant for storing secrets (e.g., passwords, API keys, …)
- Capability to force **rotation of secrets** every X days
  - Automate generation of secrets on rotation (uses Lambda)
  - Natively supports Amazon RDS (all supported DB engines), Redshift, DocumentDB
  - Support other databases and services (custom Lambda function)
- Control access to secrets using Resource-based Policy
- Integration with other AWS services to natively pull secrets from Secrets Manager: *CloudFormation, CodeBuild, ECS, EMR, Fargate, EKS, Parameter Store…*



NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

Secrets Manager – with CloudFormation

```yaml
Resources:
  # Secret resource with a randomly generated password in its SecureString JSON
  MyRDSDBInstanceRotationSecret:
    Type: AWS::SecretsManager::Secret
    Properties:
      GenerateSecretString:
        SecretStringTemplate: '{"username": "admin"}'
        GenerateStringKey: password
        PasswordLength: 16
        ExcludeCharacters: "\"@/\\"

  # RDS Instance resource. Its master username and password use dynamic references
  # to resolve values from Secrets Manager
  MyRDSDBInstance:
    Type: AWS::RDS::DBInstance
    Properties:
      DBInstanceClass: db.t2.micro
      Engine: mysql
      MasterUsername: !Sub "{{resolve:secretsmanager:${MyRDSDBInstanceRotationSecret}::username}}"
      MasterUserPassword: !Sub "{{resolve:secretsmanager:${MyRDSDBInstanceRotationSecret}::password}}"

  # SecretTargetAttachment resource which updates the referenced Secret with properties
  # about the referenced RDS instance
  SecretRDSDBInstanceAttachment:
    Type: AWS::SecretsManager::SecretTargetAttachment
    Properties:
      TargetType: AWS::RDS::DBInstance
      SecretId: !Ref MyRDSDBInstanceRotationSecret
      TargetId: !Ref MyRDSDBInstance
```

secret is generated

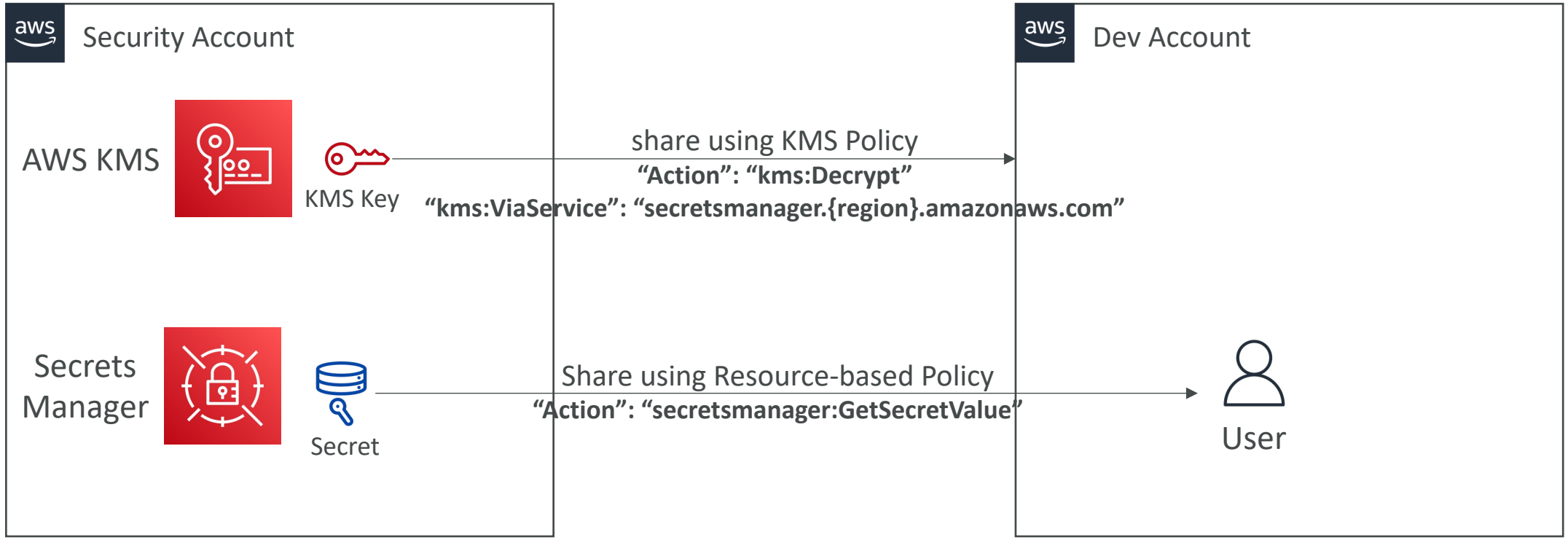
reference secret in RDS DB instance

link the secret to RDS DB instance

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Secrets Manager – Sharing Across Accounts



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSM Parameter Store vs Secrets Manager

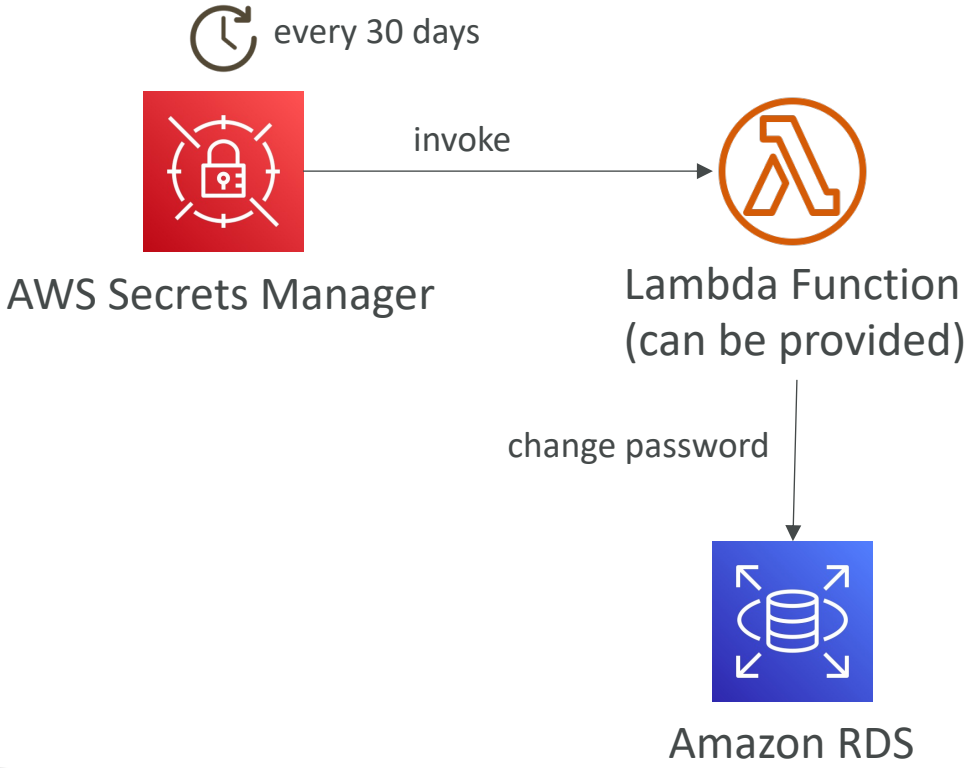
- Secrets Manager ($$$):
  - Automatic rotation of secrets with AWS Lambda
  - Lambda function is provided for RDS, Redshift, DocumentDB
  - KMS encryption is mandatory
  - Can integration with CloudFormation
- SSM Parameter Store ($):
  - Simple API
  - No secret rotation (can enable rotation using Lambda triggered by EventBridge)
  - KMS encryption is optional
  - Can integration with CloudFormation
  - Can pull a Secrets Manager secret using the SSM Parameter Store API

© Stephane Maarek

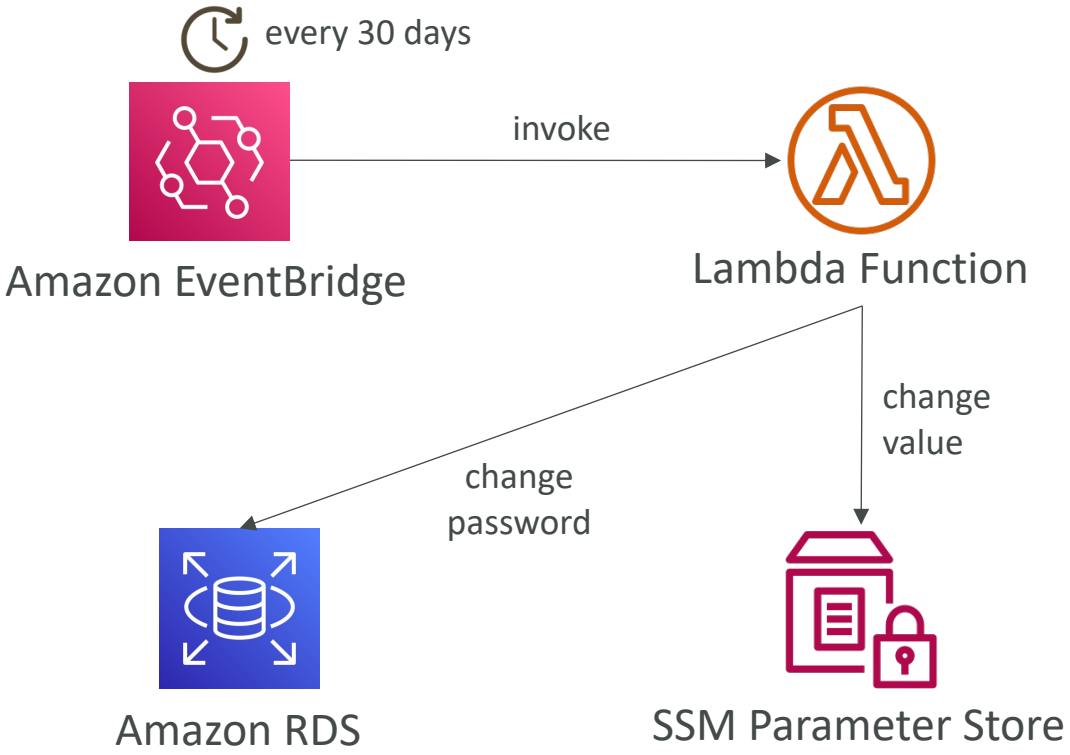
NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSM Parameter Store vs. Secrets Manager Rotation

AWS Secrets Manager



SSM Parameter Store



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

RDS - Security



- KMS encryption at rest for underlying EBS volumes / snapshots
- Transparent Data Encryption (TDE) for Oracle and SQL Server
- SSL encryption to RDS is possible for all DB (in-flight)
- IAM authentication for MySQL, PostgreSQL and MariaDB
- Authorization still happens within RDS (not in IAM)
- Can copy an un-encrypted RDS snapshot into an encrypted one
- CloudTrail cannot be used to track queries made within RDS

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSL/TLS - Basics

- **SSL** refers to Secure Sockets Layer, used to encrypt connections
- **TLS** refers to Transport Layer Security, which is a newer version
- Nowadays, **TLS certificates are mainly used**, but people still refer as SSL

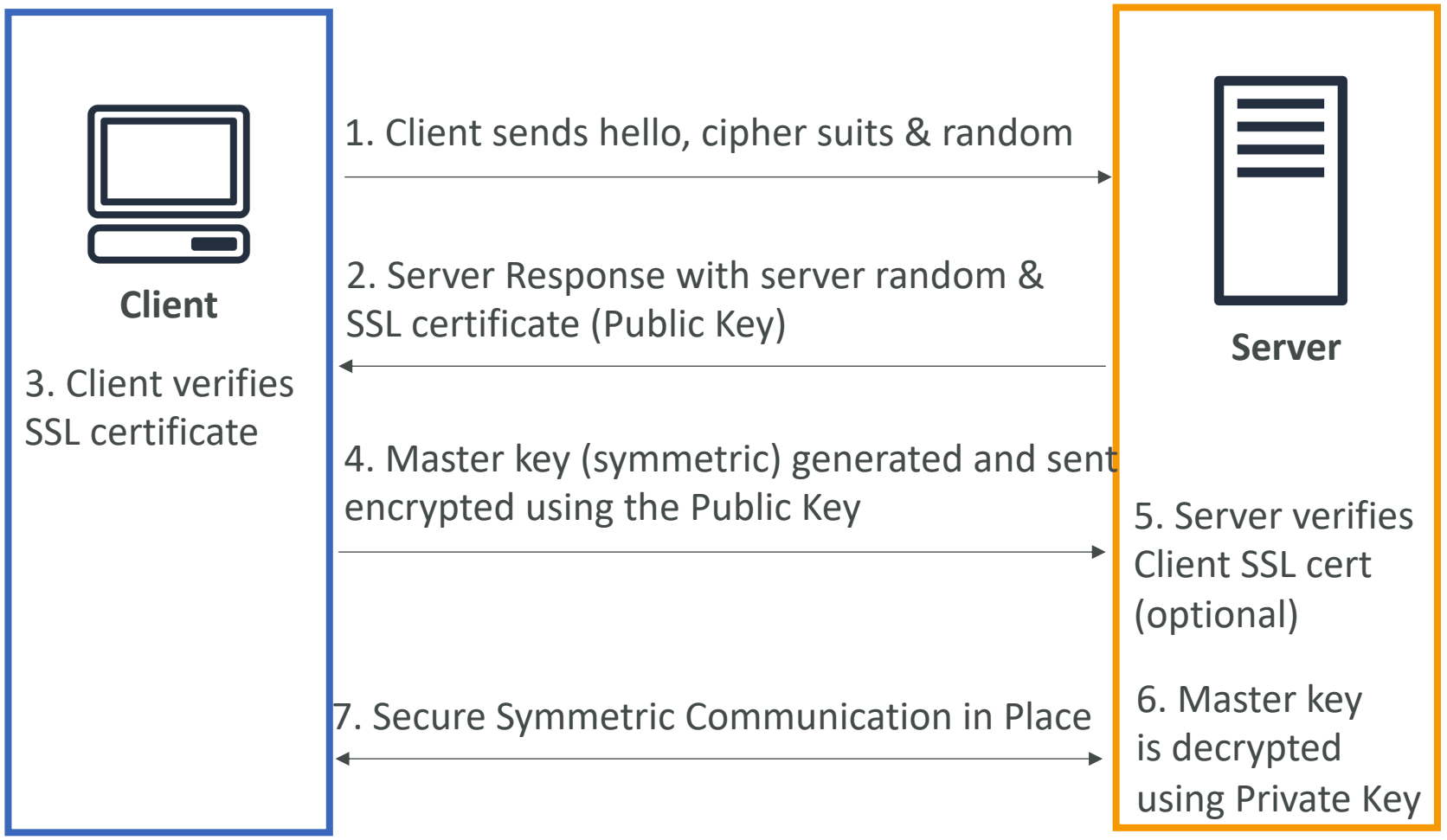
- Public SSL certificates are issued by Certificate Authorities (CA)
- Comodo, Symantec, GoDaddy, GlobalSign, Digicert, Letsencrypt, etc…

- SSL certificates have an expiration date (you set) and must be renewed

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSL Encryption – How it works



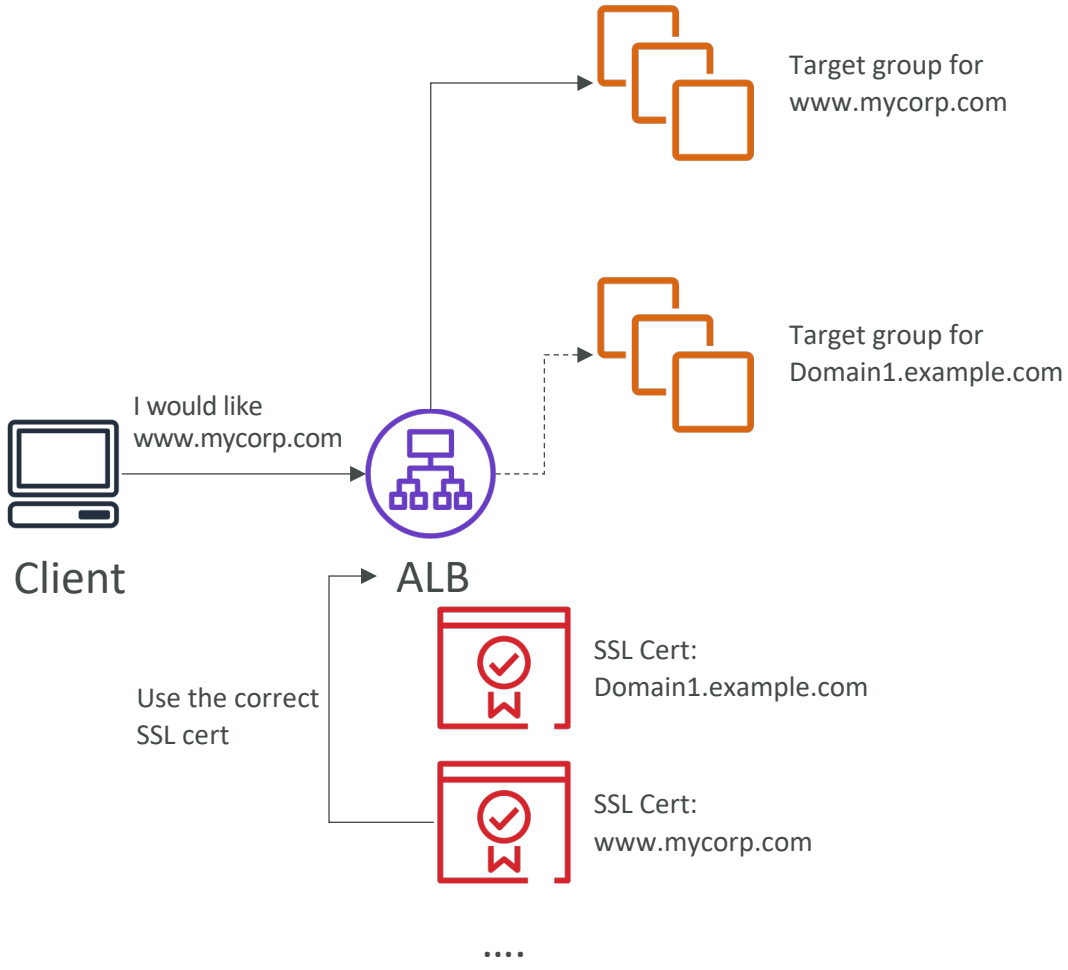
- Asymmetric Encryption is expensive (SSL)
- Symmetric encryption is cheaper
- Asymmetric handshake is used to exchange a per-client random symmetric key
- Possibility of client sending an SSL certificate as well (two-way certificate)

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

SSL – Server Name Indication (SNI)

- SNI solves the problem of loading **multiple SSL certificates onto one web server** (to serve multiple websites)
- It's a "newer" protocol, and requires the client to **indicate** the hostname of the target server in the initial SSL handshake
- The server will then find the correct certificate, or return the default one



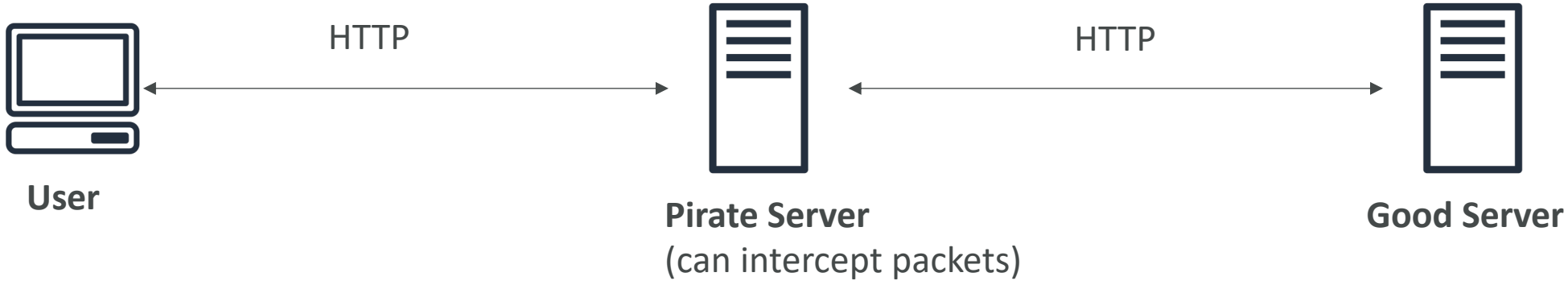
Note:

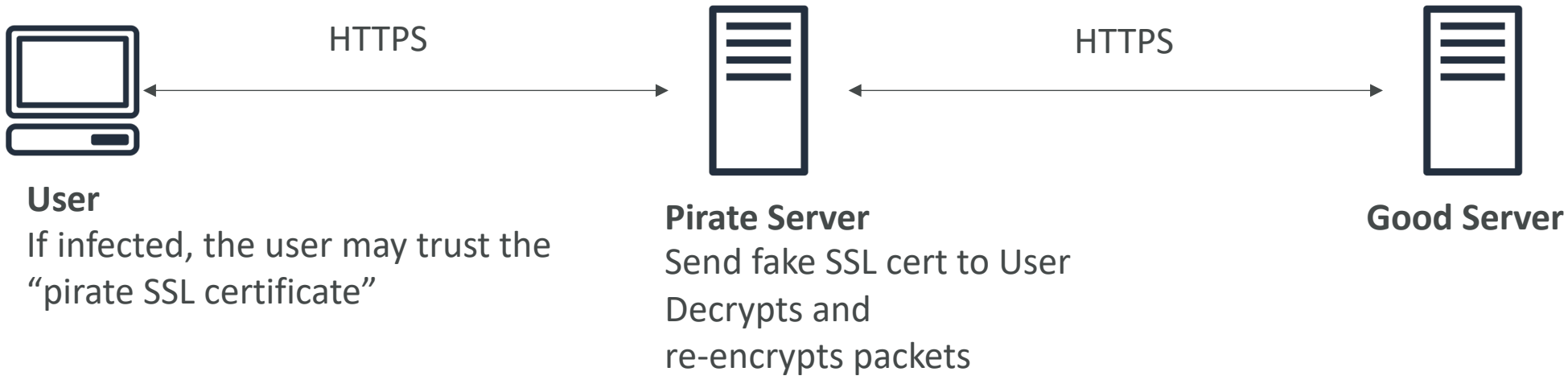
- Only works for ALB & NLB (newer generation), CloudFront
- Does not work for CLB (older gen)

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSL – Man in the Middle Attacks





© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SSL – Man in the Middle Attack
How to prevent

1. Don't use public-facing HTTP, use HTTPS (meaning, use SSL/TLS certificates)
2. Use a DNS that has DNSSEC
   - To send a client to a pirate server, a DNS response needs to be "forged" by a server which intercepts them
   - It is possible to protect your domain name by configuring DNSSEC
   - **Amazon Route 53 supports DNSSEC for domain registration.**
   - **Route 53 supports DNSSEC for DNS service as of December 2020 (using KMS)**
   - You could also run a custom DNS server on Amazon EC2 for example (**Bind** is the most popular, dnsmasq, KnotDNS, PowerDNS).

© Stephane Maarek

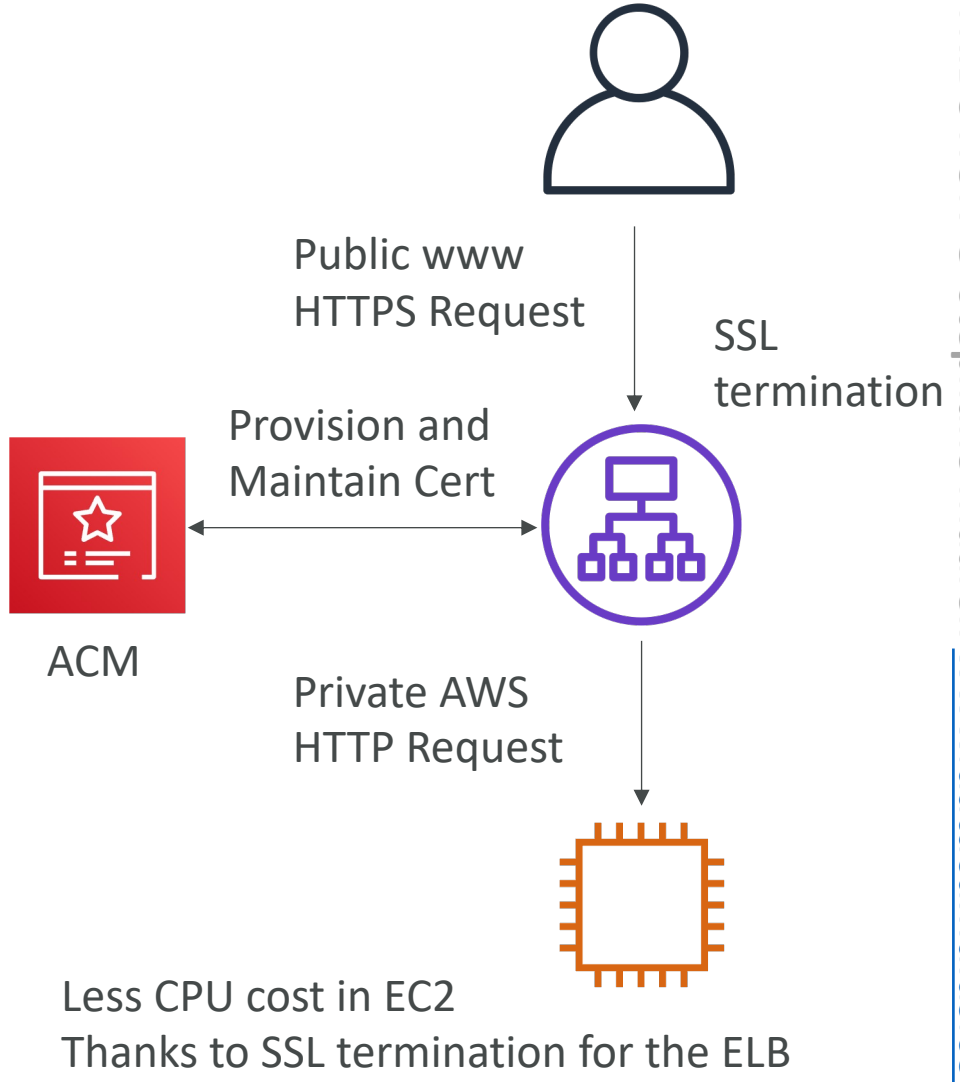
NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Certificate Manager (ACM)

- To host public SSL certificates in AWS, you can:
  - Buy your own and upload them using the CLI
  - Have ACM provision and renew public SSL certificates for you (free of cost)

- ACM loads SSL certificates on the following integrations:
  - Load Balancers (including the ones created by EB)
  - CloudFront distributions
  - APIs on API Gateways

- SSL certificates is overall a pain to manually manage, so ACM is great to leverage in your AWS infrastructure!



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

ACM – Good to know

- Possibility of creating public certificates
  - Must verify public DNS
  - Must be issued by a trusted public certificate authority (CA)
- Possibility of creating private certificates
  - For your internal applications
  - You create your own private CA
  - Your applications must trust your private CA
- Certificate renewal:
  - Automatically done if generated provisioned by ACM
  - Any manually uploaded certificates must be renewed manually and re-uploaded
- ACM is a **regional** service
  - To use with a global application (multiple ALB for example), you need to issue an SSL certificate in each region where you application is deployed.
  - You cannot copy certs across regions

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudHSM

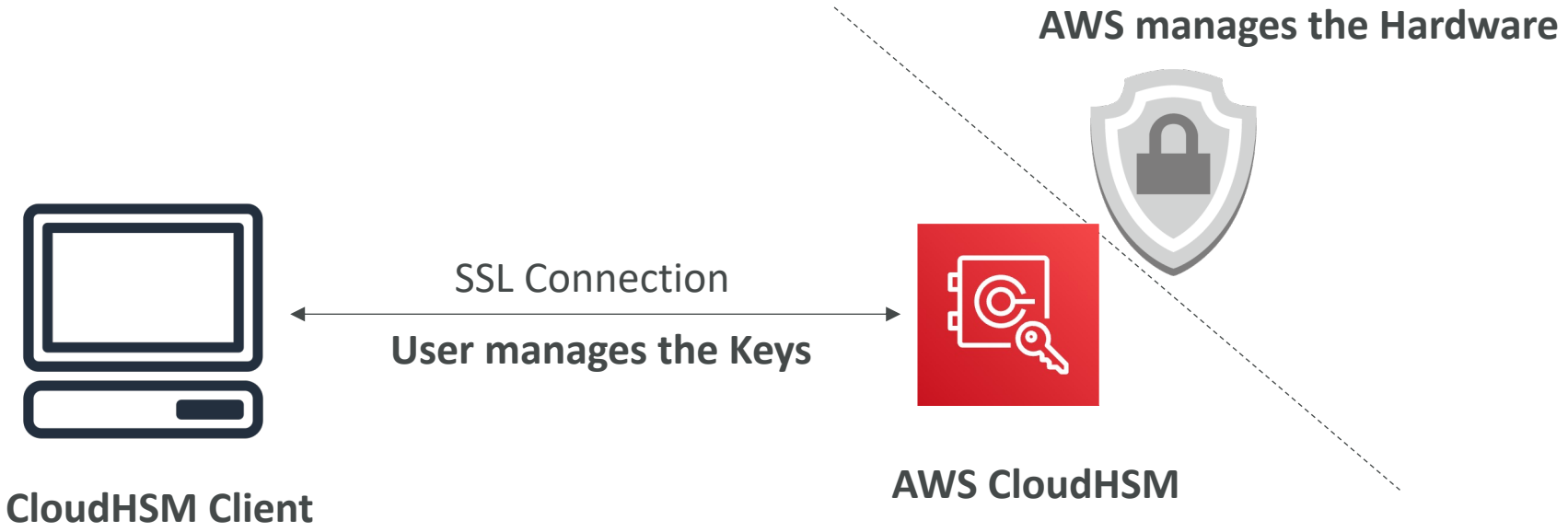


- KMS => AWS manages the software for encryption
- CloudHSM => AWS provisions encryption **hardware**
- Dedicated Hardware (HSM = Hardware Security Module)
- You manage your own encryption keys entirely (not AWS)
- HSM device is tamper resistant, FIPS 140-2 Level 3 compliance
- Supports both symmetric and **asymmetric** encryption (SSL/TLS keys)
- No free tier available
- Must use the CloudHSM Client Software
- Redshift supports CloudHSM for database encryption and key management
- **Good option to use with SSE-C encryption**

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudHSM Diagram



IAM permissions:

- CRUD an HSM Cluster

CloudHSM Software:

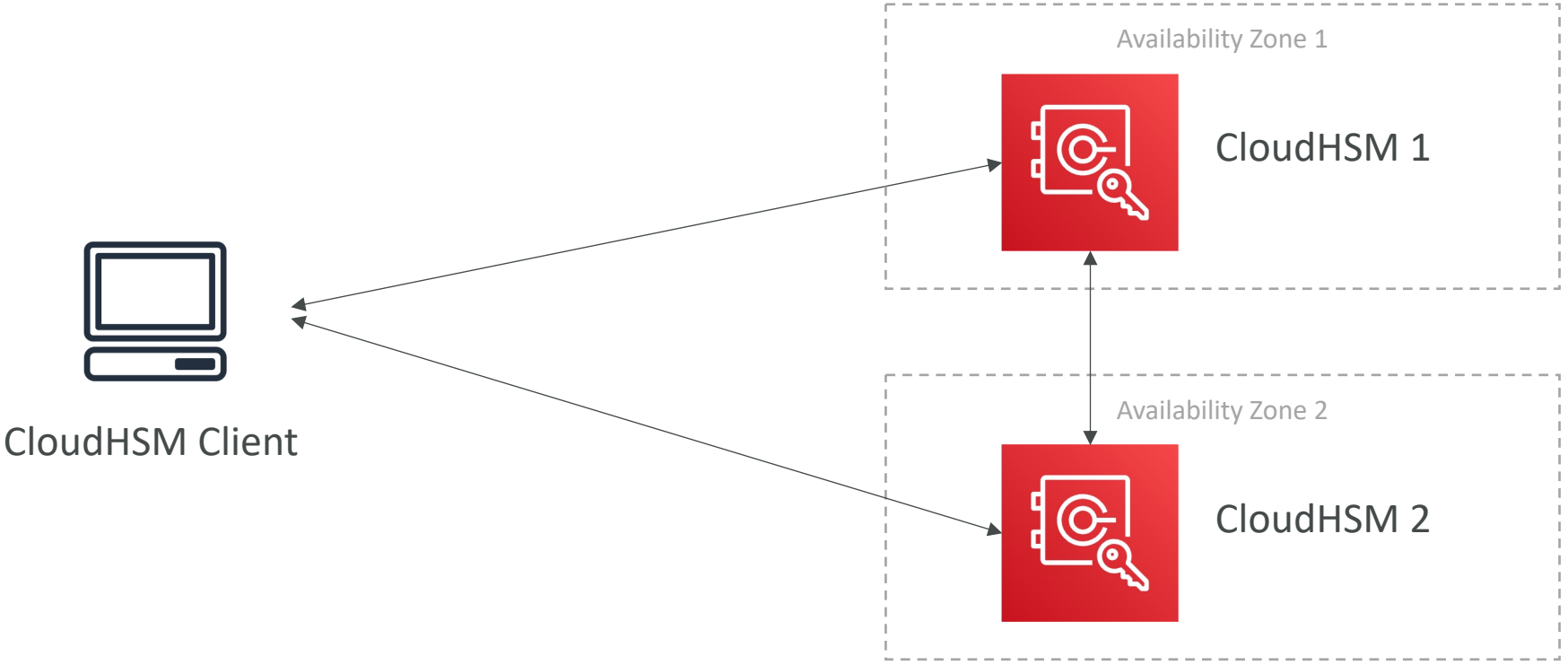
- Manage the Keys
- Manage the Users

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudHSM – High Availability

- CloudHSM clusters are spread across Multi AZ (HA)
- Great for availability and durability



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

CloudHSM vs. KMS

Feature	AWS KMS	AWS CloudHSM
Tenancy	Multi-Tenant	Single-Tenant
Standard	FIPS 140-2 Level 3	FIPS 140-2 Level 3
Master Keys	• AWS Owned Keys • AWS Managed Keys • Customer Managed KMS Keys	Customer Managed CMK
Key Types	• Symmetric • Asymmetric • Digital Signing	• Symmetric • Asymmetric • Digital Signing & Hashing
Key Accessibility	Accessible in multiple AWS regions KMS Key Replication	• Deployed and managed in a VPC • Can be shared across VPCs (VPC Peering)
Cryptographic Acceleration	None	• SSL/TLS Acceleration • Oracle TDE Acceleration
Access & Authentication	AWS IAM	You create users and manage their permissions

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

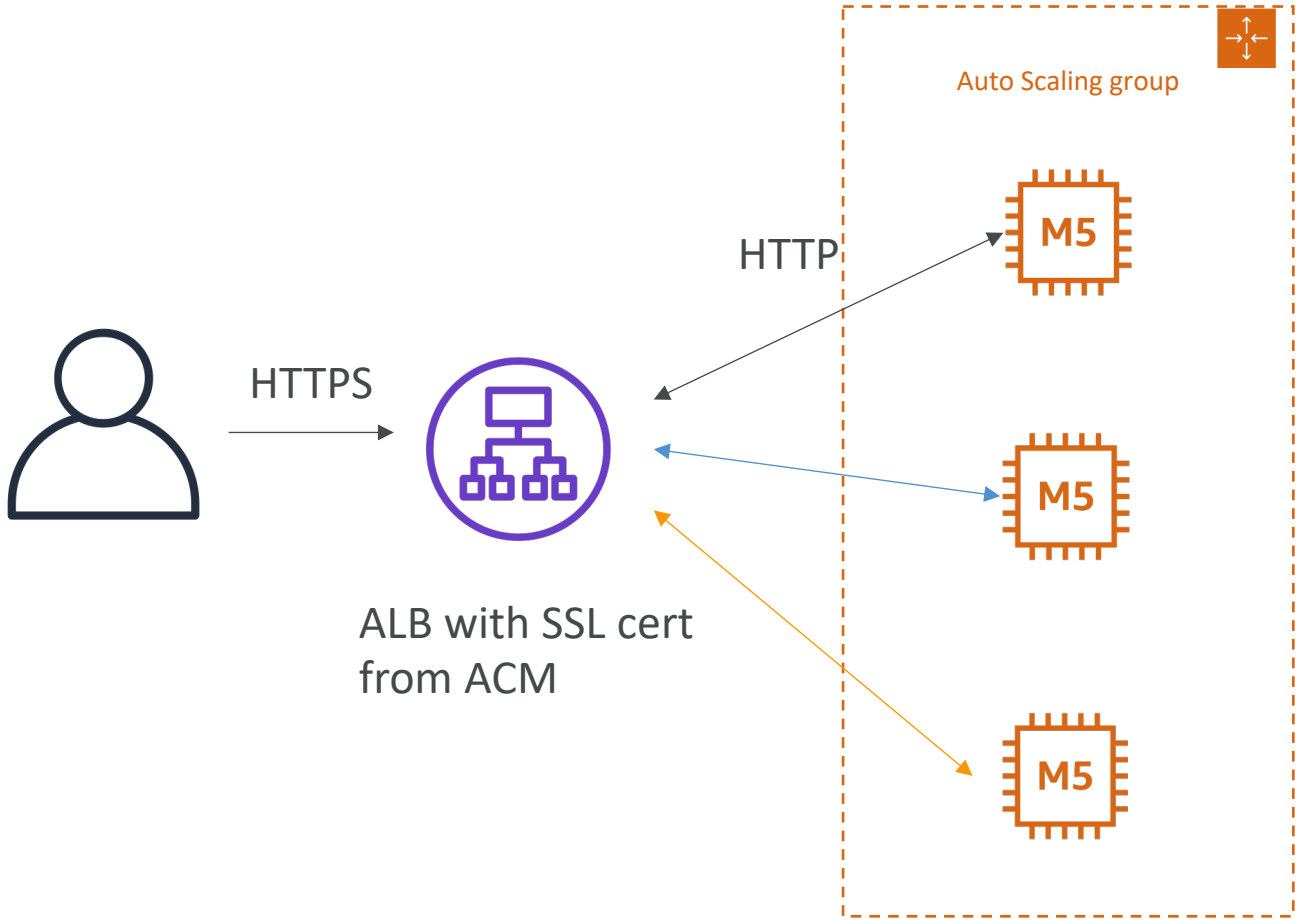
CloudHSM vs. KMS

Feature	AWS KMS	AWS CloudHSM
High Availability	AWS Managed Service	Add multiple HSMs over different AZs
Audit Capability	• CloudTrail • CloudWatch	• CloudTrail • CloudWatch • MFA support
Free Tier	Yes	No

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

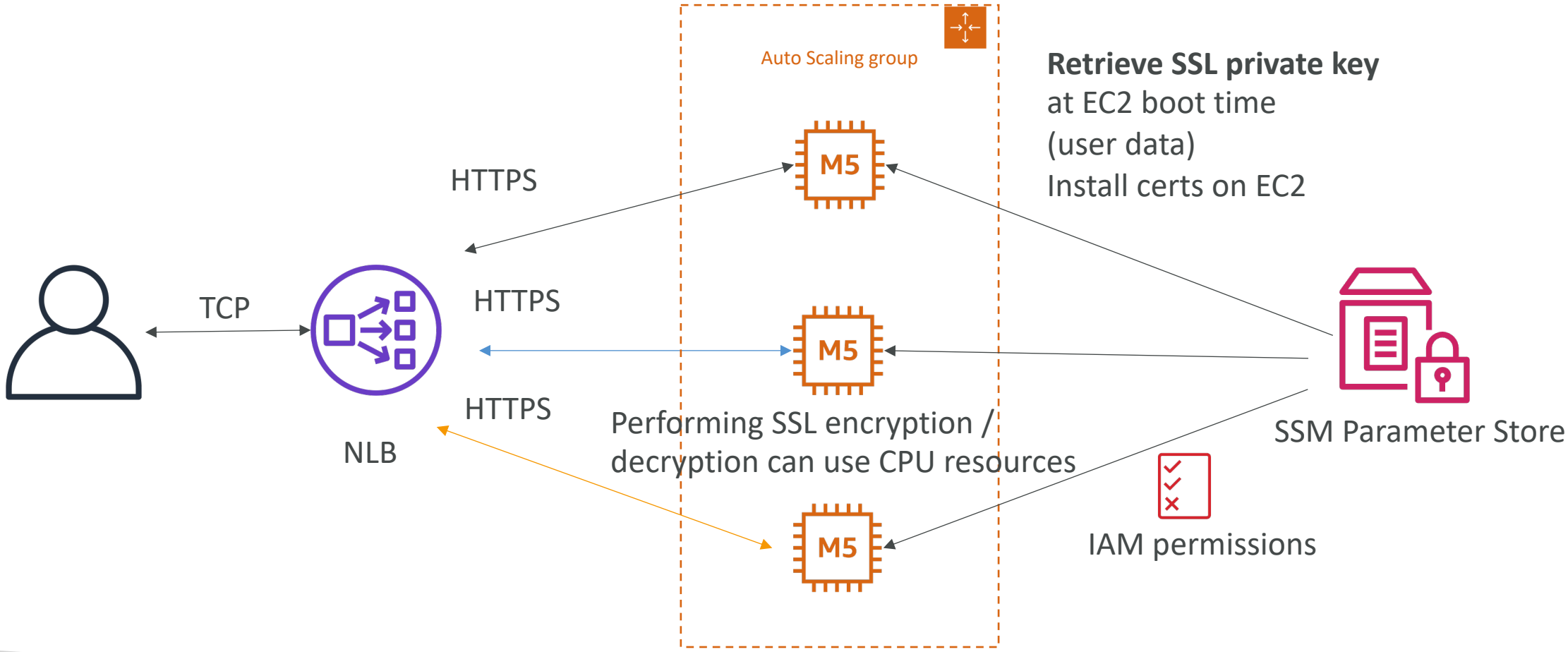
Solution Architecture: SSL on ALB



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Solution Architecture:
SSL on web server EC2 instances

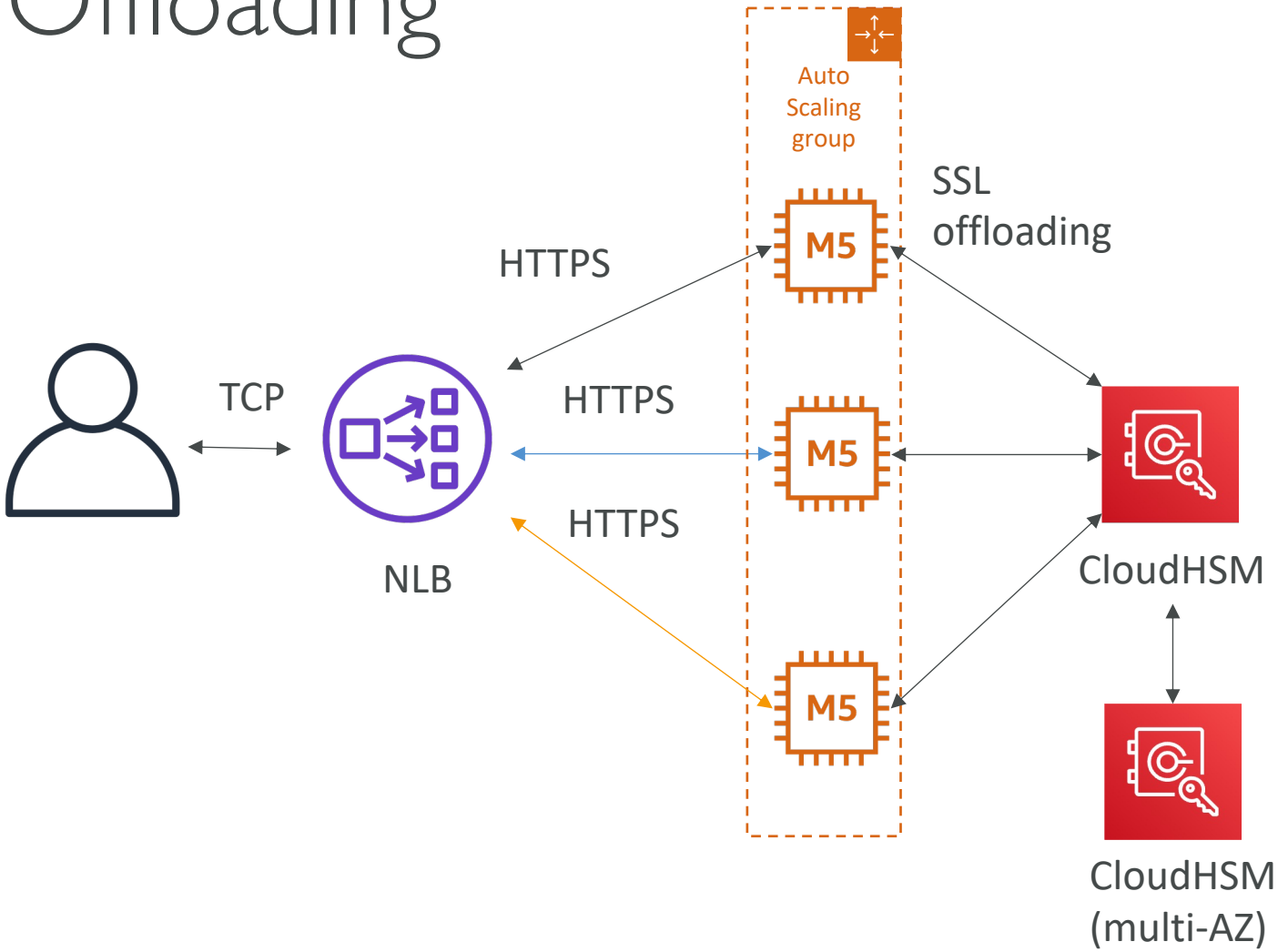


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Solution Architecture: CloudHSM – SSL Offloading

- You can offload SSL to CloudHSM (SSL Acceleration)
- Supported by NGINX, Apache Web servers and IIS for Windows Server
- Extra security: the SSL private key never leaves the HSM device
- Must setup a cryptographic user (CU) on the CloudHSM device



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 Encryption for Objects

- **SSE-S3:** encrypts S3 objects using keys handled & managed by AWS
- **SSE-KMS**: leverage KMS to manage encryption keys
  - Key usage appears in CloudTrail
  - objects made public can never be read
  - On *s3:PutObject*, make the permission *kms:GenerateDataKey* is allowed
- **SSE-C**: when you want to manage your own encryption keys
- Client-Side Encryption

- **Glacier:** all data is AES-256 encrypted, key under AWS control

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Encryption in transit (SSL / TLS)

- Amazon S3 exposes:
  - HTTP endpoint: non encrypted
  - HTTPS endpoint: encryption in flight

- You're free to use the endpoint you want, but HTTPS is recommended
- HTTPS is mandatory for SSE-C

- To enforce HTTPS, use a Bucket Policy with aws:SecureTransport

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Events in S3 Buckets

- S3 Access Logs:
  - Detailed records for the requests that are made to a bucket
  - Might take hours to deliver
  - Might be incomplete (best effort)
- S3 Events Notifications:
  - Receive notifications when certain events happen in your bucket
  - E.g.: new objects created, object removal, restore objects, replication events
  - Destinations: SNS, SQS queue, Lambda
  - Typically delivered in seconds but can take minutes, notification for every object if versioning is enabled, else risk of one notification for two same object write done simultaneously
- Trusted Advisor:
  - Check the bucket permission (is the bucket public?)
- Amazon EventBridge:
  - Need to enable CloudTrail object level logging on S3 first
  - Target can be Lambda, SQS, SNS, etc…

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 Security

- User based
  - IAM policies - which API calls should be allowed for a specific user from IAM console
- Resource Based
  - Bucket Policies - bucket wide rules from the S3 console - allows cross account
  - Object Access Control List (ACL) – finer grain
  - Bucket Access Control List (ACL) – less common

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 Bucket Policies

- Use S3 bucket for policy to:
  - Grant public access to the bucket
  - Force objects to be encrypted at upload
  - **Grant access to another account (Cross Account)**
- Optional Conditions on:
  - **SourceIp**: Public IP or Elastic IP | **VpcSourceIp**: Private IP (through VPC Endpoint)
  - Source VPC or Source VPC Endpoint – only works with VPC Endpoints
  - CloudFront Origin Identity
  - MFA
- Examples here: https://docs.aws.amazon.com/AmazonS3/latest/dev/example-bucket-policies.html

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 pre-signed URLs

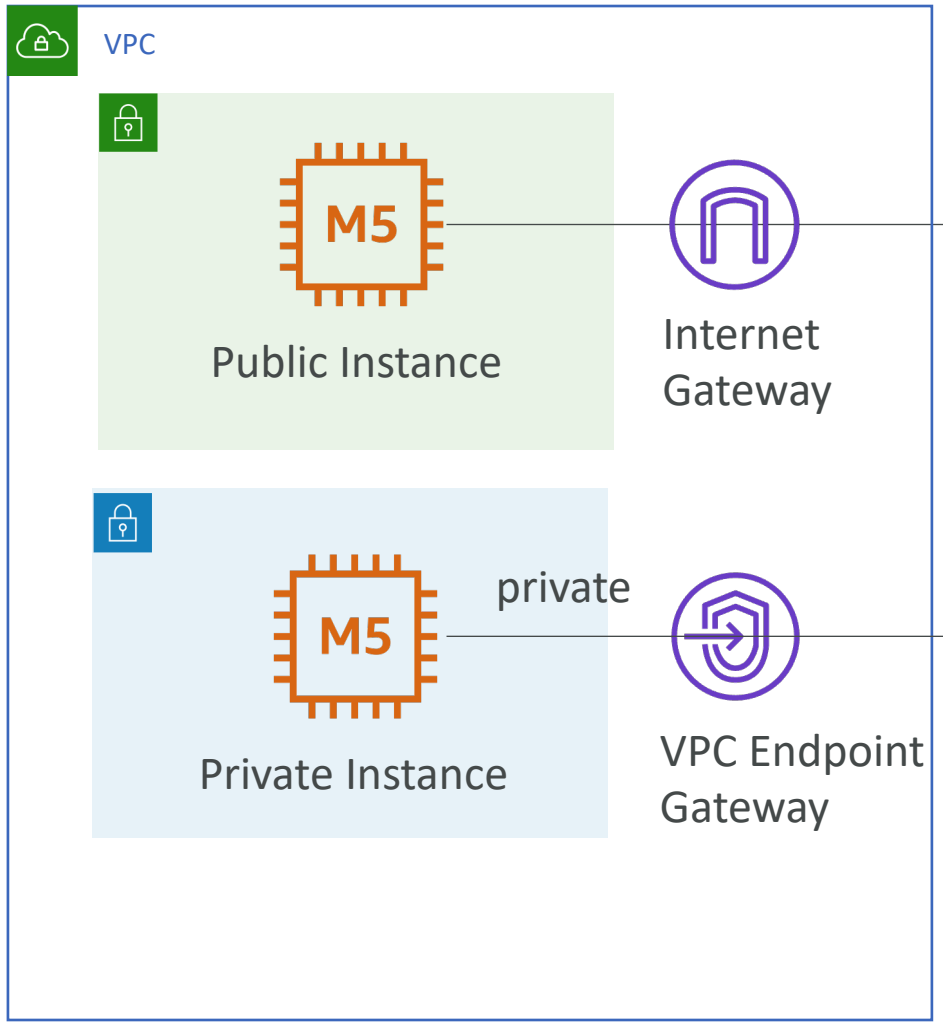
- Can generate pre-signed URLs using SDK or CLI
  - For downloads (easy, can use the CLI)
  - For uploads (harder, must use the SDK)
- Valid for a default of 3600 seconds, can change timeout with --expires-in [TIME_BY_SECONDS] argument
- Users given a pre-signed URL inherit the permissions of the person who generated the URL for GET / PUT

- Examples :
  - Allow only logged-in users to download a premium video on your S3 bucket
  - Allow an ever changing list of users to download files by generating URLs dynamically
  - Allow temporarily a user to upload a file to a precise location in our bucket

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

VPC Endpoint Gateway for S3



Public www



S3 Bucket
Bucket policy by **AWS:SourceIP (public IP)**



S3 Bucket
Bucket policy by
AWS:SourceVpce
(one or few endpoints)

OR

AWS:SourceVpc
(encompass all possible VPC endpoints)

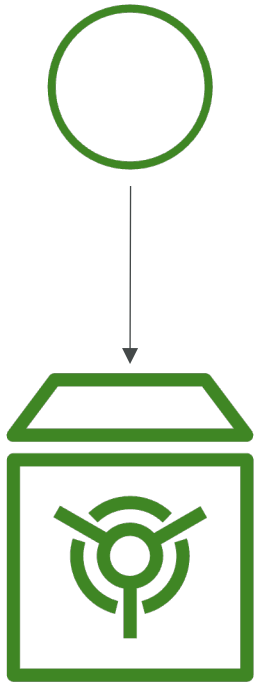
© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 Object Lock & Glacier Vault Lock

- S3 Object Lock
  - Adopt a WORM (Write Once Read Many) model
  - Block an object version deletion for a specified amount of time

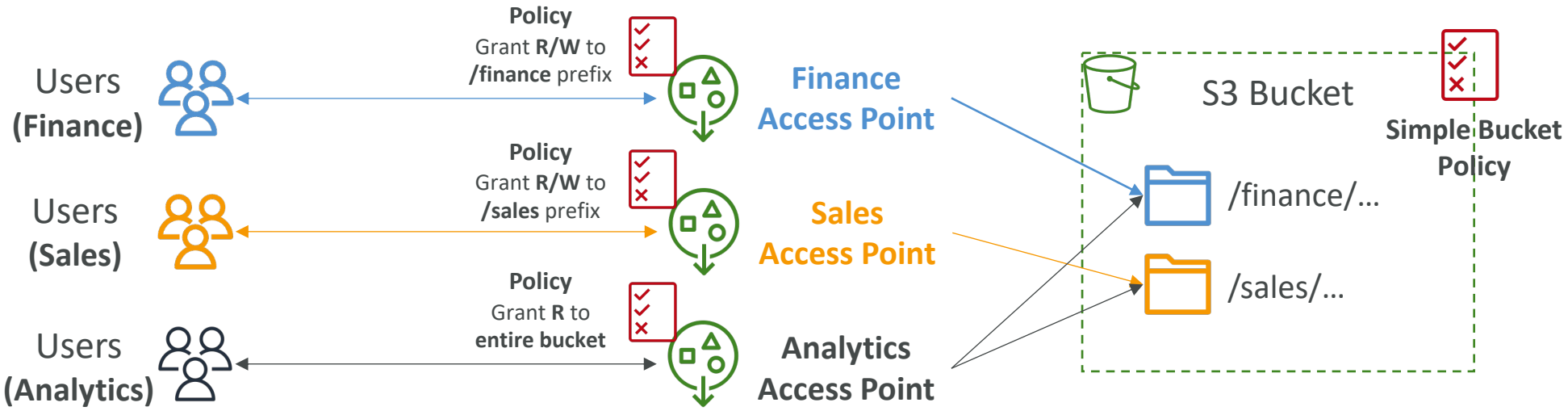
- Glacier Vault Lock
  - Adopt a WORM (Write Once Read Many) model
  - Lock the policy for future edits (can no longer be changed)
  - Helpful for compliance and data retention



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 – Access Points



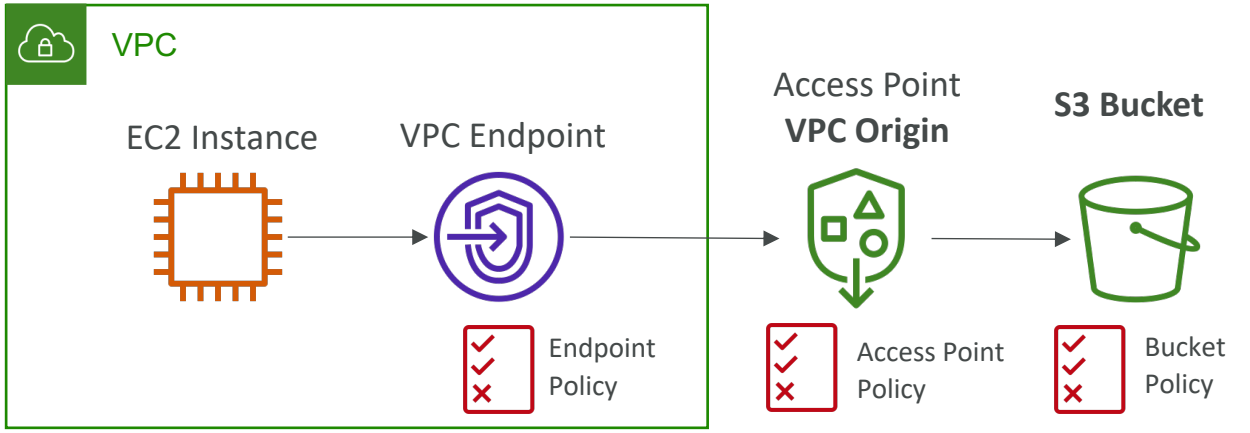
- Access Points simplify security management for S3 Buckets
- Each Access Point has:
  - its own DNS name (Internet Origin or VPC Origin)
  - an access point policy (similar to bucket policy) – manage security at scale

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 – Access Points – VPC Origin

- We can define the access point to be accessible only from within the VPC
- You must create a VPC Endpoint to access the Access Point (Gateway or Interface Endpoint)
- The VPC Endpoint Policy must allow access to the target bucket and Access Point



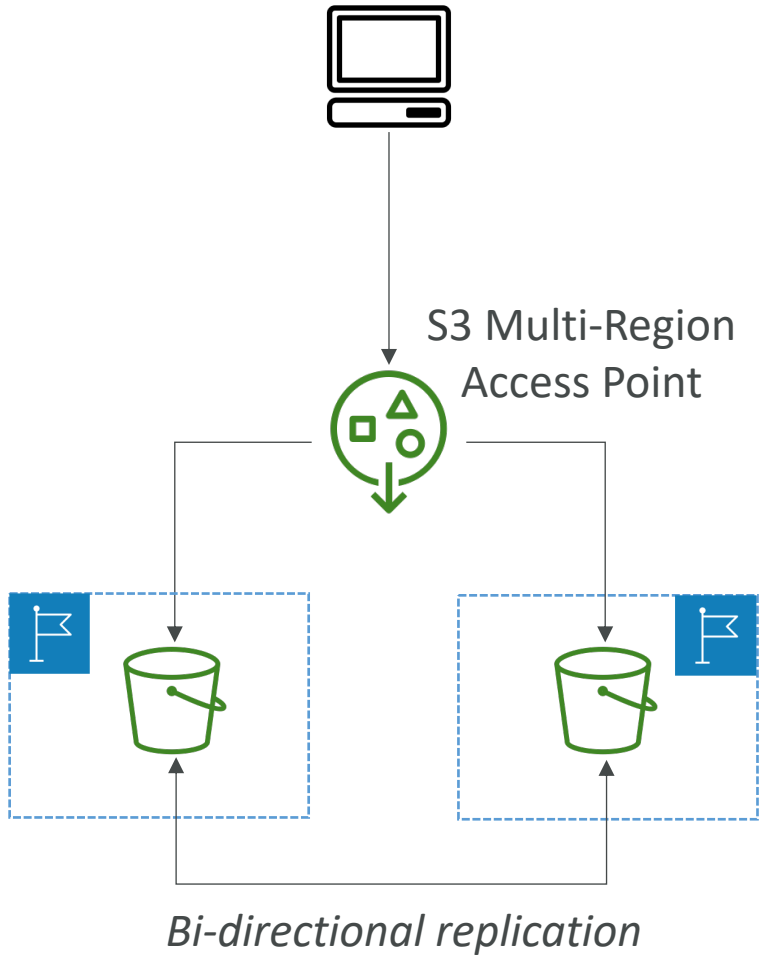

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Principal": "*",
            "Action": [
                "s3:GetObject"
            ],
            "Effect": "Allow",
            "Resource": [
                "arn:aws:s3:::awsexamplebucket1/*",
                "arn:aws:s3:us-west-2:123456789012:accesspoint/example-vpc-ap/object/*"
            ]
        }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 – Multi-Region Access Points

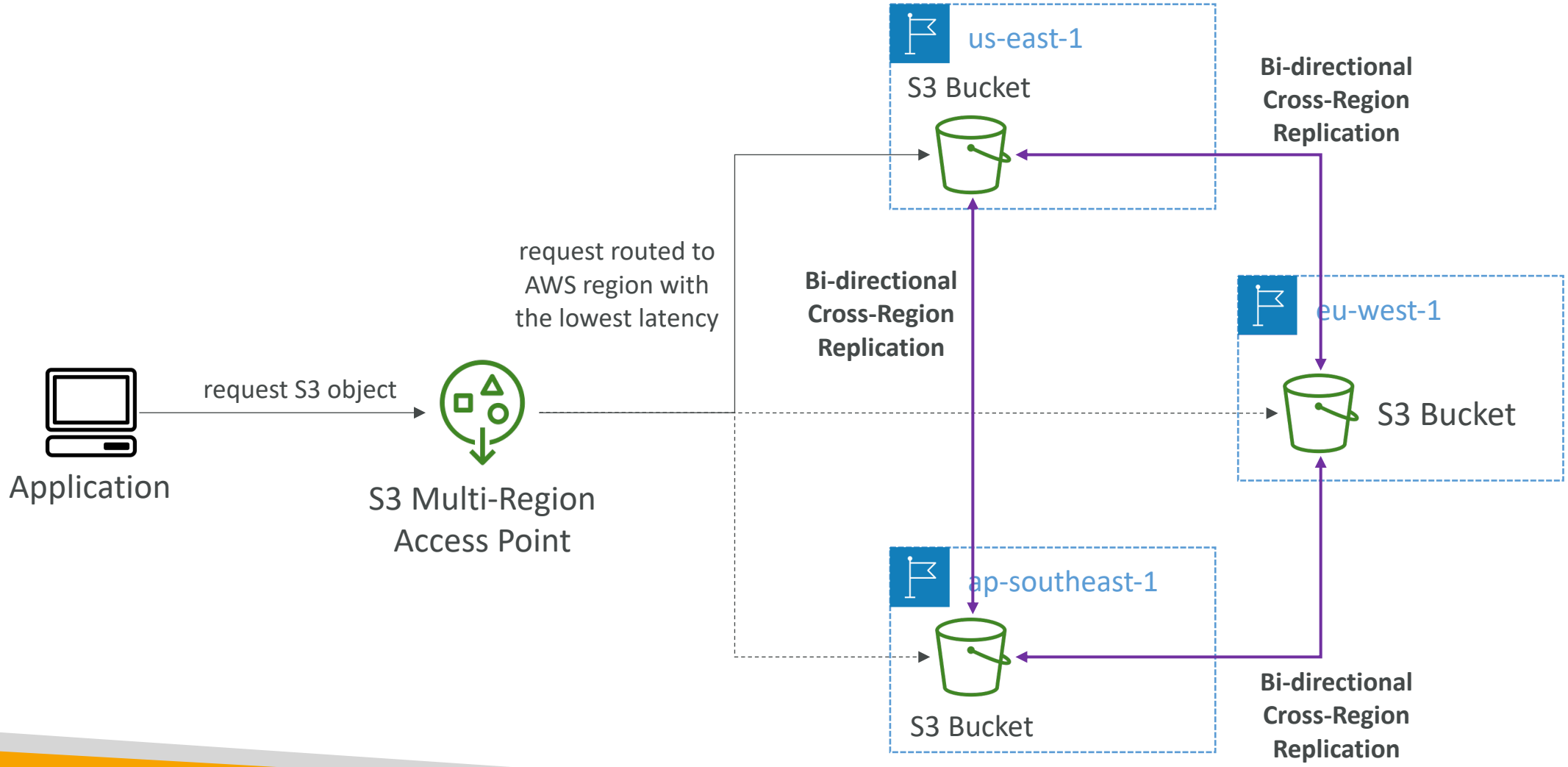
- Provide a global endpoint that span S3 buckets in multiple AWS regions
- Dynamically route requests to the nearest S3 bucket (lowest latency)
- Bi-directional S3 bucket replication rules are created to keep data in sync across regions
- **Failover Controls** – allows you to shift requests across S3 buckets in different AWS regions within minutes (Active-Active or Active-Passive)



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

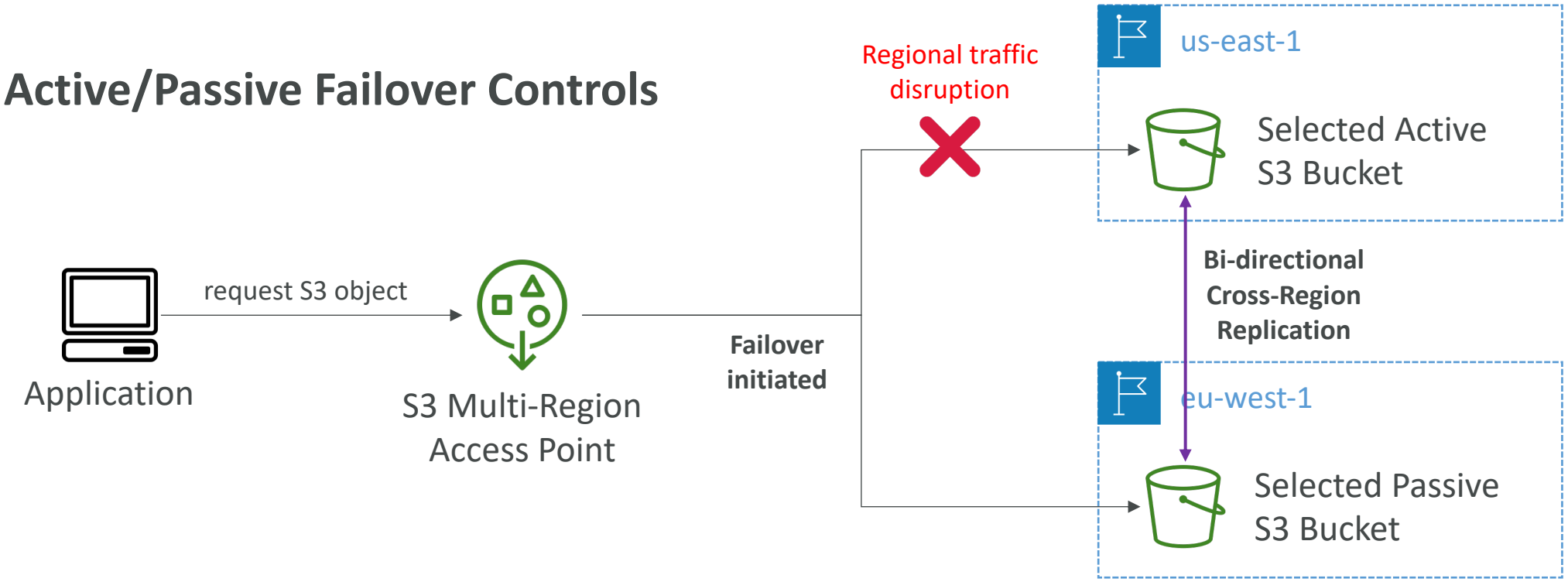
S3 – Multi-Region Access Points



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Multi-Region Access Points – Failover Controls



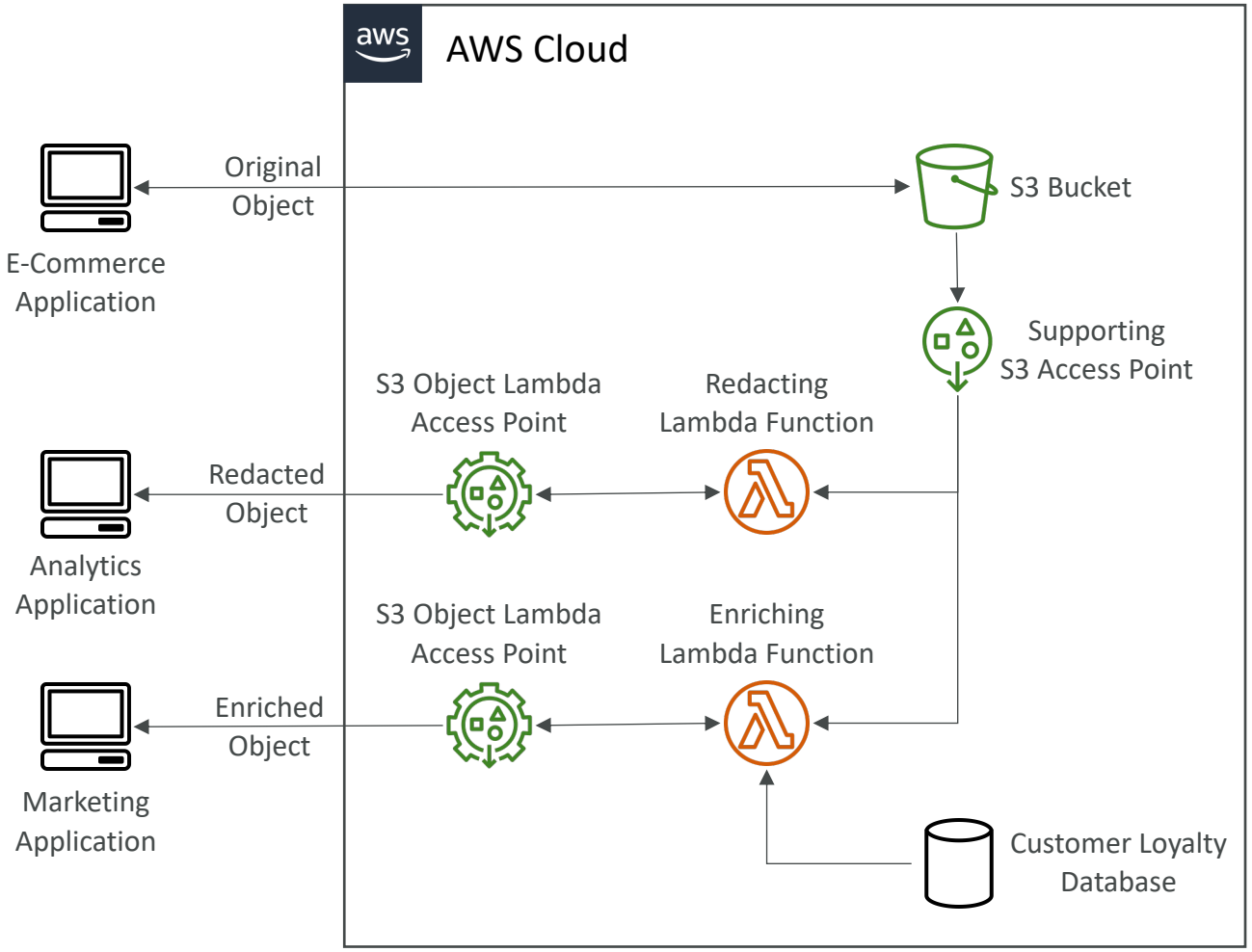
Works with active/active or active/passive setups

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

S3 Object Lambda

- Use AWS Lambda Functions to change the object before it is retrieved by the caller application
- Only one S3 bucket is needed, on top of which we create **S3 Access Point** and **S3 Object Lambda Access Points.**
- Use Cases:
  - Redacting personally identifiable information for analytics or non-production environments.
  - Converting across data formats, such as converting XML to JSON.
  - Resizing and watermarking images on the fly using caller-specific details, such as the user who requested the object.

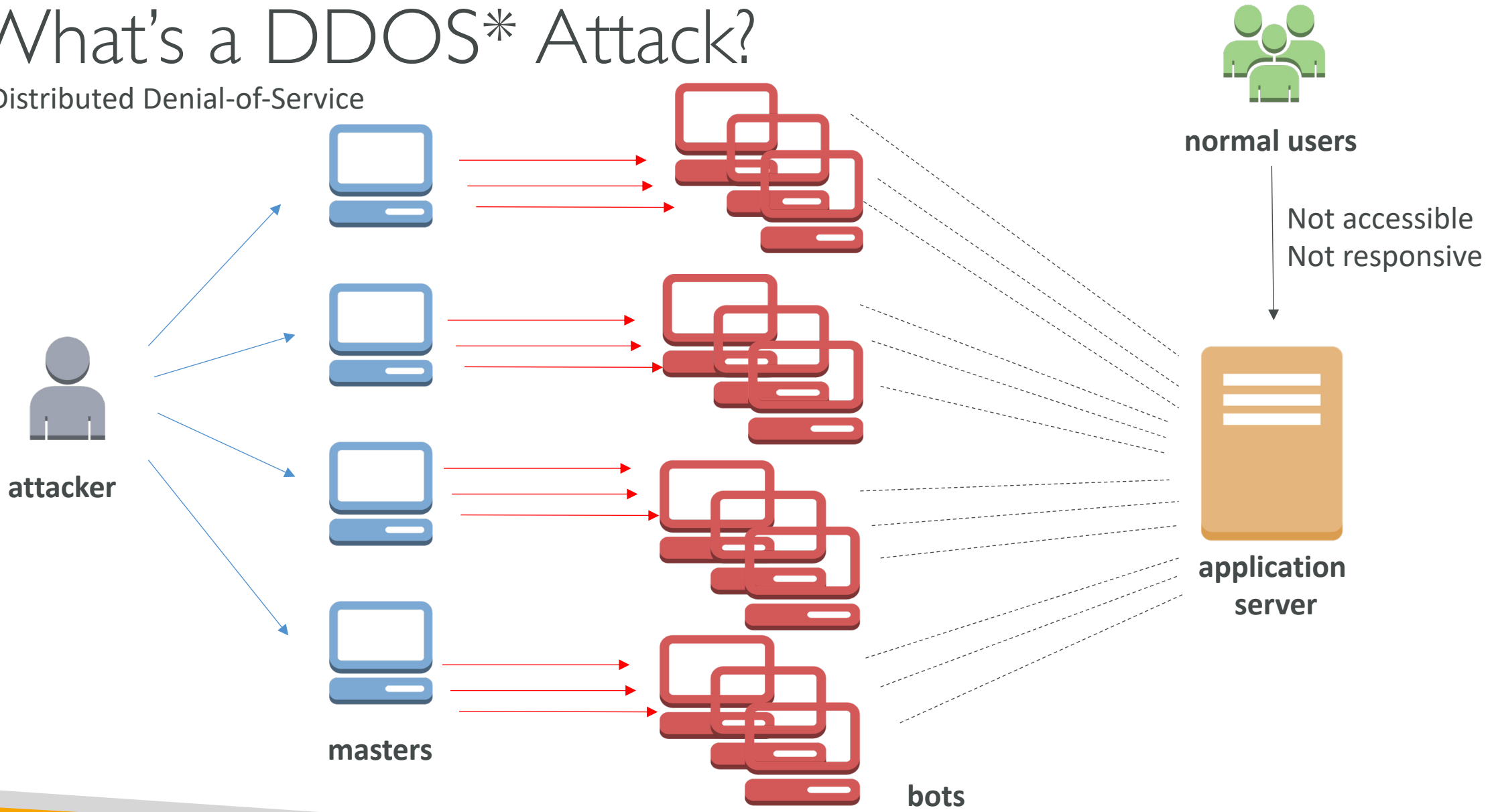


NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

What's a DDOS* Attack?

*Distributed Denial-of-Service



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Type of Attacks on your infrastructure

- Distributed Denial of Service (DDoS):
  - When your service is unavailable because it's receiving too many requests
  - SYN Flood (Layer 4): send too many TCP connection requests
  - UDP Reflection (Layer 4): get other servers to send many big UDP requests
  - DNS flood attack: overwhelm the DNS so legitimate users can't find the site
  - Slow Loris attack: a lot of HTTP connections are opened and maintained

- Application level attacks:
  - more complex, more specific (HTTP level)
  - Cache bursting strategies: overload the backend database by invalidating cache

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

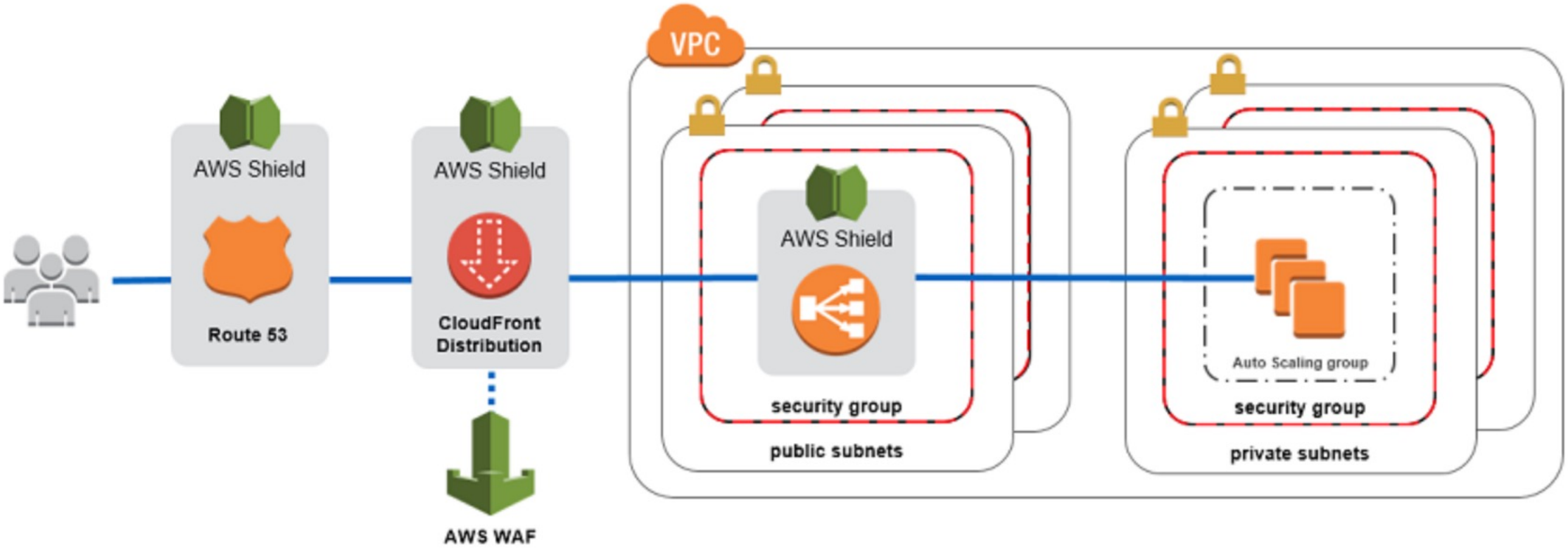
DDoS Protection on AWS

- **AWS Shield Standard:** protects against DDoS attack for your website and applications, for all customers at no additional costs
- **AWS Shield Advanced:** 24/7 premium DDoS protection
- **AWS WAF:** Filter specific requests based on rules
- **CloudFront and Route 53:**
  - Availability protection using global edge network
  - Combined with AWS Shield, provides DDoS attack mitigation at the edge
- Be ready to scale – leverage AWS Auto Scaling
- Separate static resources (S3 / CloudFront) from dynamic ones (EC2 / ALB)
- Read the whitepaper for details: https://d1.awsstatic.com/whitepapers/Security/DDoS_White_Paper.pdf

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Sample Reference Architecture



https://aws.amazon.com/answers/networking/aws-ddos-attack-mitigation/

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Shield



- AWS Shield Standard:
  - Free service that is activated for every AWS customer
  - Provides protection from attacks such as SYN/UDP Floods, Reflection attacks and other layer 3/layer 4 attacks
- AWS Shield Advanced:
  - Optional DDoS mitigation service ($3,000 per month per organization)
  - Protect against more sophisticated attack on Amazon EC2, Elastic Load Balancing (ELB), Amazon CloudFront, AWS Global Accelerator, Route 53
  - 24/7 access to AWS DDoS response team (DRP)
  - Protect against higher fees during usage spikes due to DDoS

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS WAF – Web Application Firewall



- Protects your web applications from common web exploits (Layer 7)
- Deploy on **Application Load Balancer** (localized rules)
- Deploy on **API Gateway** (rules running at the regional or edge level)
- Deploy on **CloudFront** (rules globally on edge locations)
  - Used to front other solutions: CLB, EC2 instances, custom origins, S3 websites
- Deploy on AppSync (protect your GraphQL APIs)
- WAF is not for DDoS protection
- Define Web ACL (Web Access Control List):
  - Rules can include **IP addresses,** HTTP headers, HTTP body, or URI strings
  - Protects from common attack - **SQL injection** and Cross-Site Scripting (XSS)
  - Size constraints, Geo match
  - Rate-based rules (to count occurrences of events)
- Rule Actions: Count | Allow | Block | CAPTCHA | Challenge

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS WAF – Managed Rules

- Library of over 190 managed rules
- Ready-to-use rules that are managed by AWS and AWS Marketplace Sellers

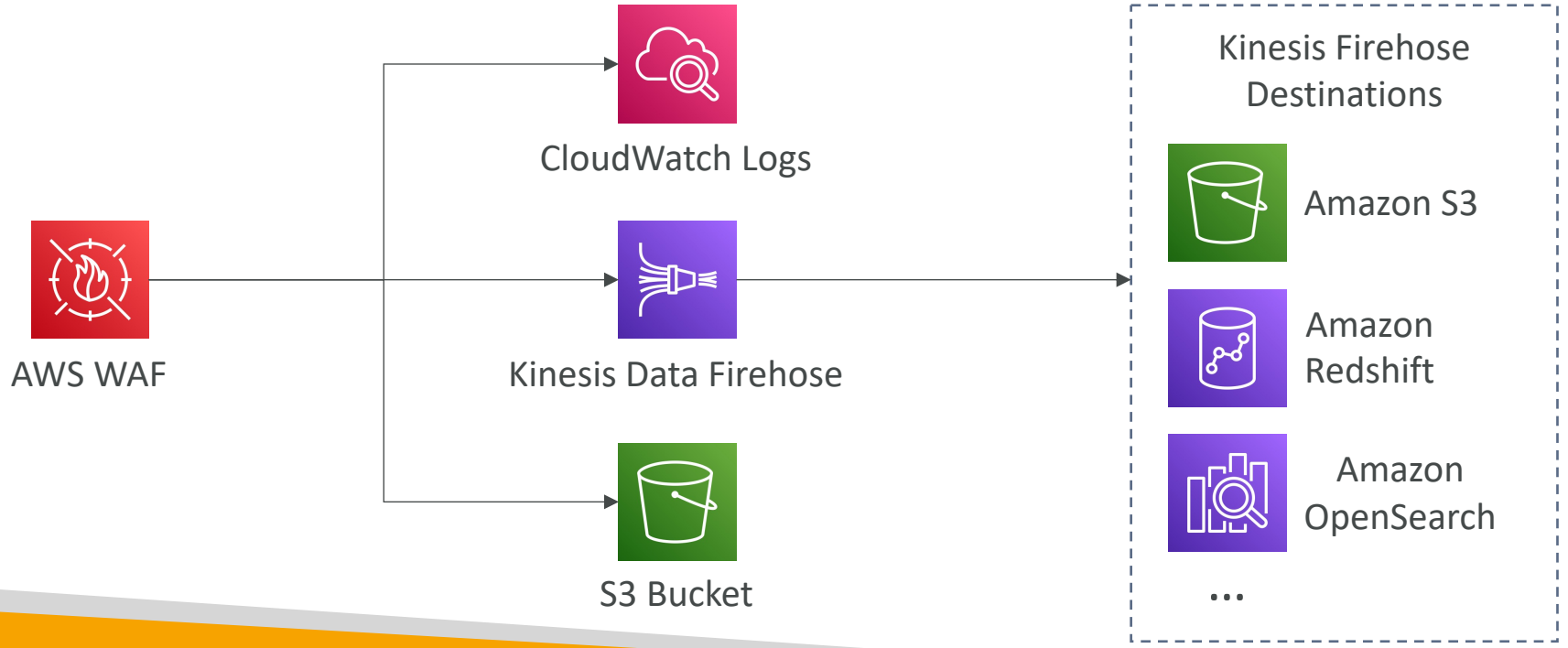
- **Baseline Rule Groups** – general protection from common threats
  - AWSManagedRulesCommonRuleSet, AWSManagedRulesAdminProtectionRuleSet, …
- **Use-case Specific Rule Groups** – protection for many AWS WAF use cases
  - AWSManagedRulesSQLiRuleSet, AWSManagedRulesWindowsRuleSet, AWSManagedRulesPHPRuleSet, AWSManagedRulesWordPressRuleSet, …
- **IP Reputation Rule Groups** – block requests based on source (e.g., malicious IPs)
  - AWSManagedRulesAmazonIpReputationList, AWSManagedRulesAnonymousIpList
- **Bot Control Managed Rule Group** – block and manage requests from bots
  - AWSManagedRulesBotControlRuleSet

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

WAF - Web ACL – Logging

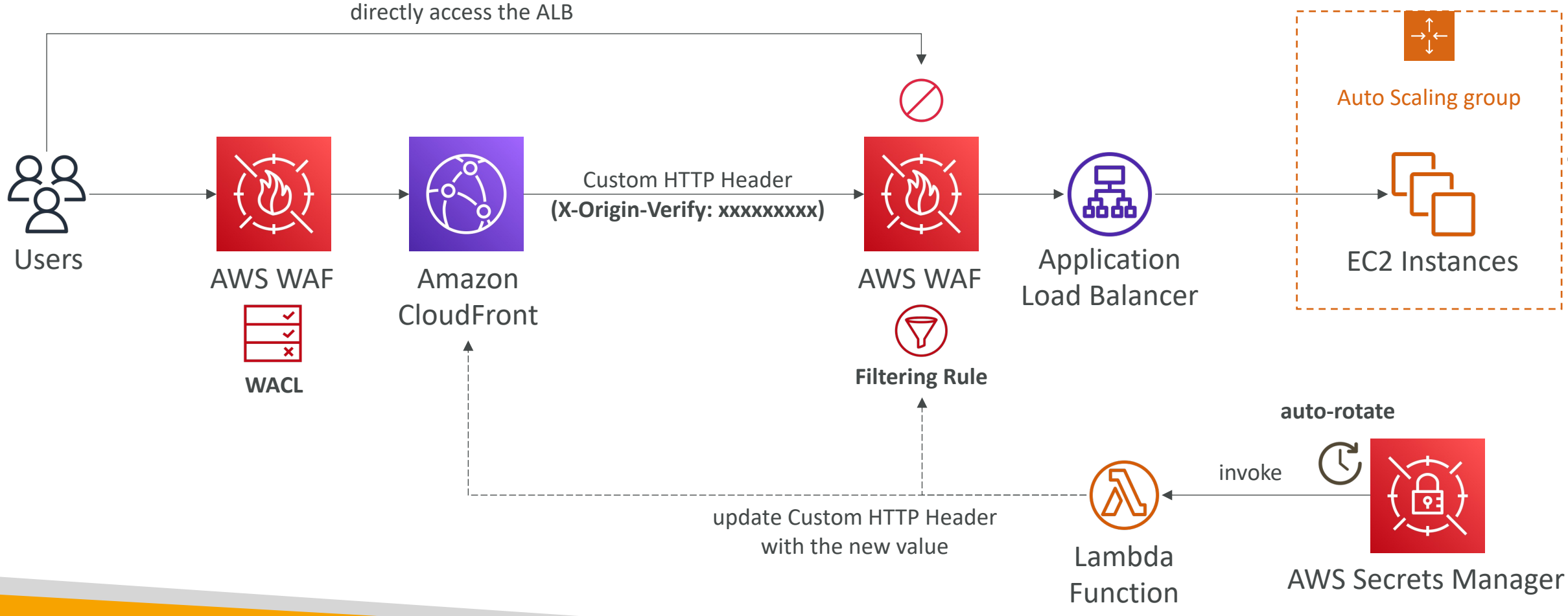
- You can send your logs to an:
  - Amazon CloudWatch Logs log group – 5 MB per second
  - Amazon Simple Storage Service (Amazon S3) bucket – 5 minutes interval
  - Amazon Kinesis Data Firehose – limited by Firehose quotas



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Solution Architecture – Enahnce CloudFront Origin Security with AWS WAF & AWS Secrets Manager



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Firewall Manager



- Manage rules in all accounts of an AWS Organization

- Security policy: common set of security rules
  - WAF rules (Application Load Balancer, API Gateways, CloudFront)
  - AWS Shield Advanced (ALB, CLB, NLB, Elastic IP, CloudFront)
  - Security Groups for EC2, Application Load Balancer and ENI resources in VPC
  - AWS Network Firewall (VPC Level)
  - Amazon Route 53 Resolver DNS Firewall
  - Policies are created at the region level

- Rules are applied to new resources as they are created (good for compliance) across all and future accounts in your Organization

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

WAF vs. Firewall Manager vs. Shield



AWS WAF



AWS Firewall Manager



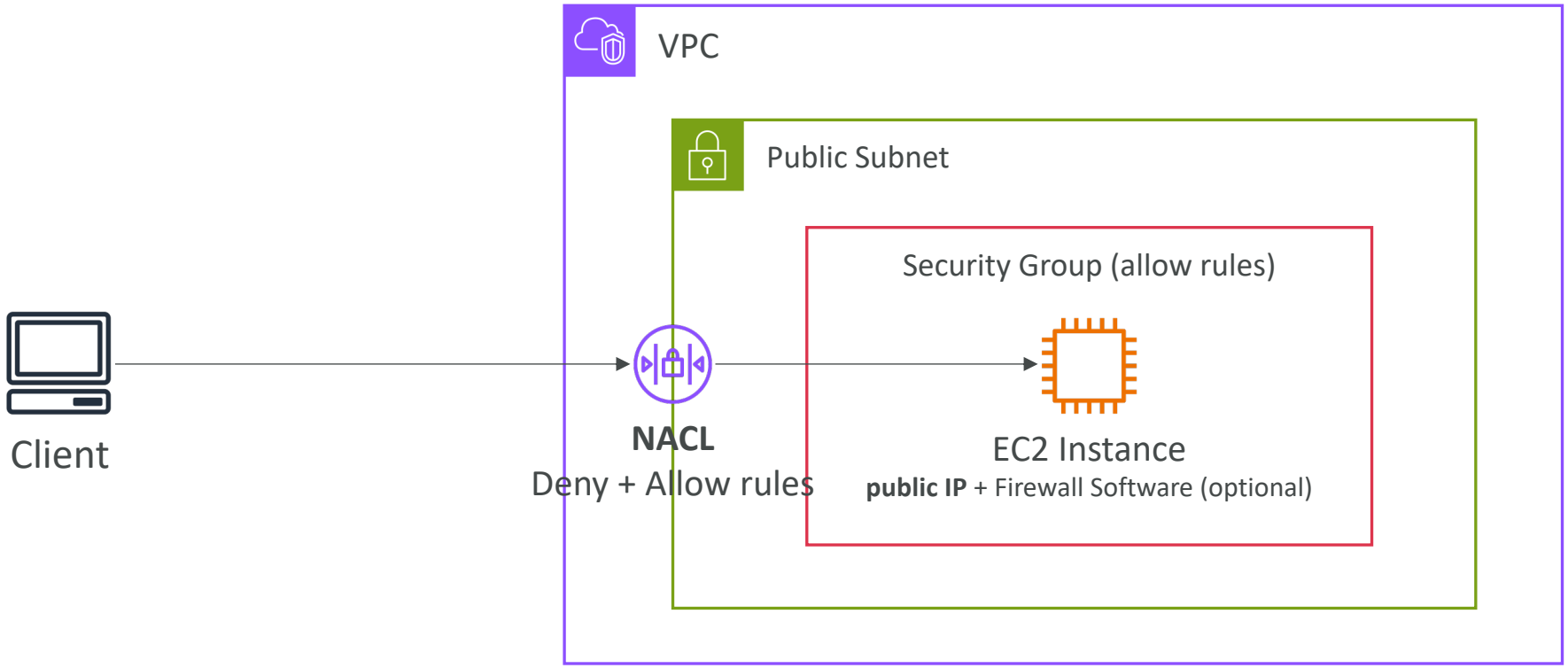
AWS Shield

- WAF, Shield and Firewall Manager are used together for comprehensive protection
- Define your Web ACL rules in WAF
- For granular protection of your resources, WAF alone is the correct choice
- If you want to use AWS WAF across accounts, accelerate WAF configuration, automate the protection of new resources, use Firewall Manager with AWS WAF
- Shield Advanced adds additional features on top of AWS WAF, such as dedicated support from the Shield Response Team (SRT) and advanced reporting.
- If you're prone to frequent DDoS attacks, consider purchasing Shield Advanced

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

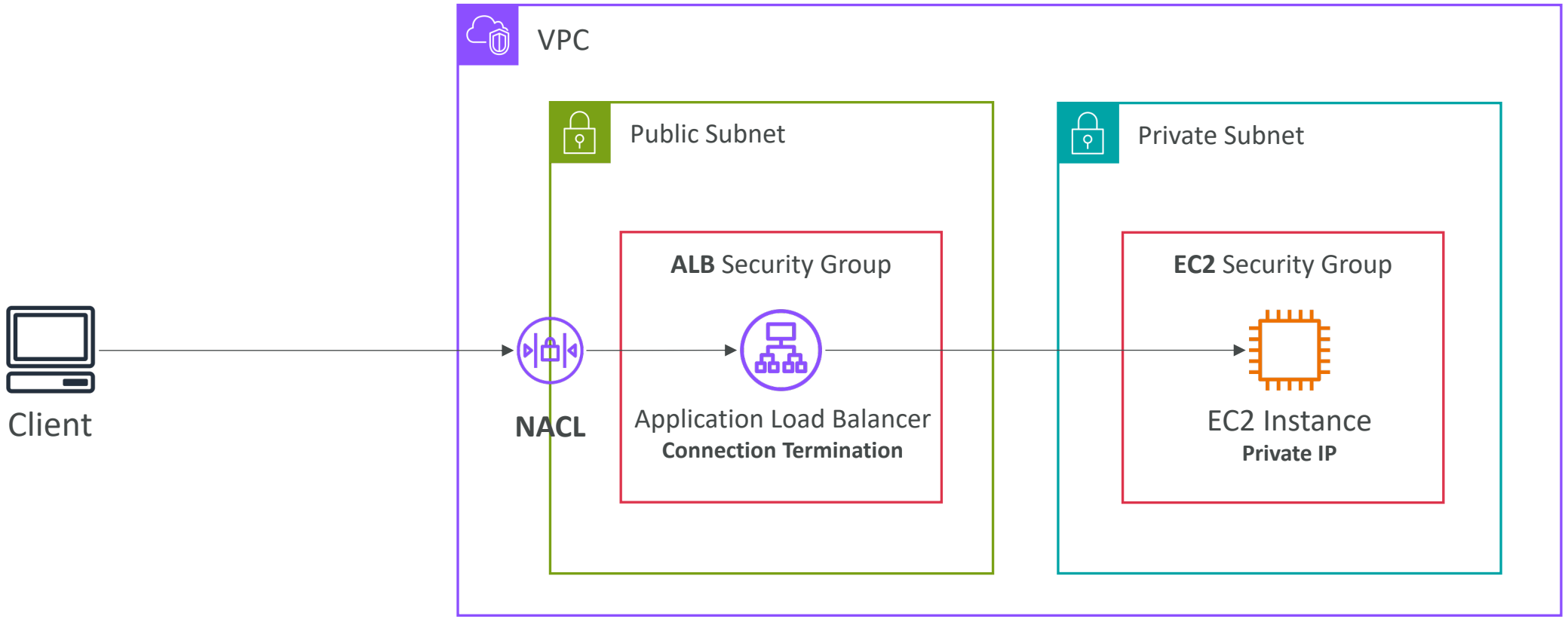
Blocking an IP address



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

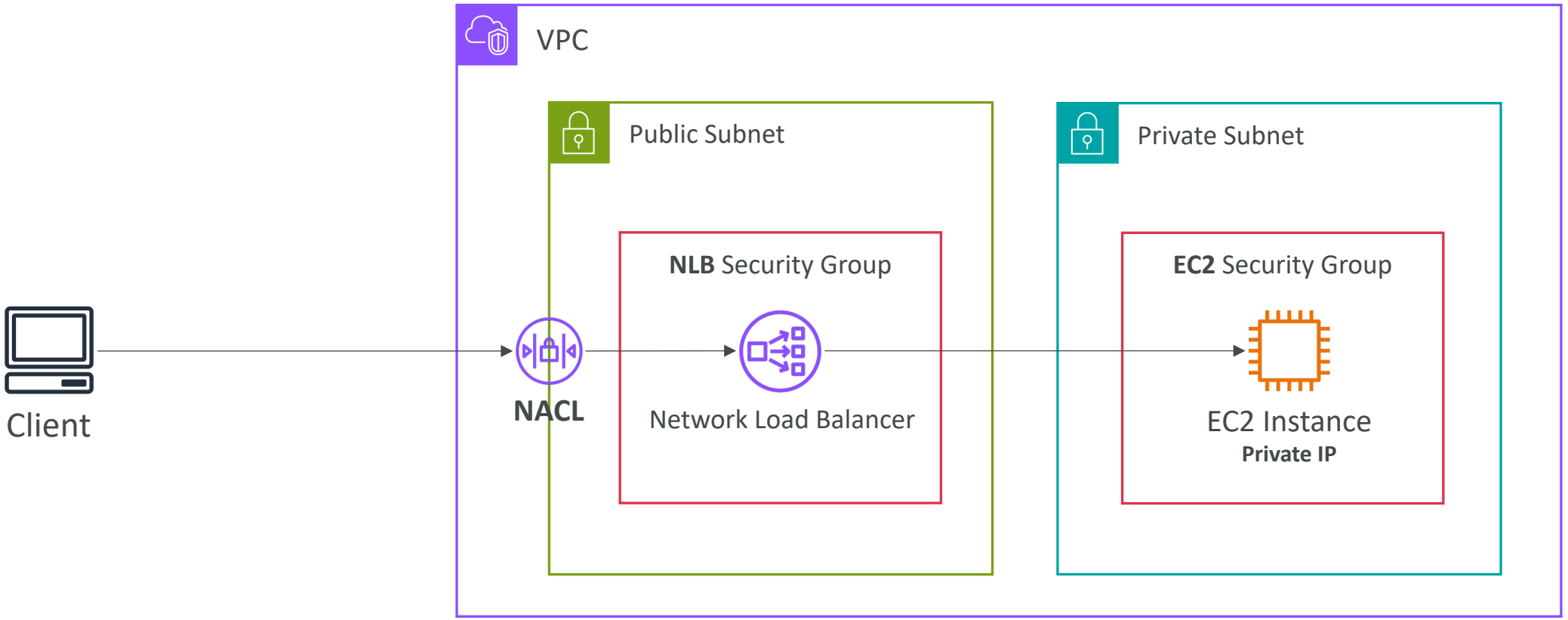
Blocking an IP address – with an ALB



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

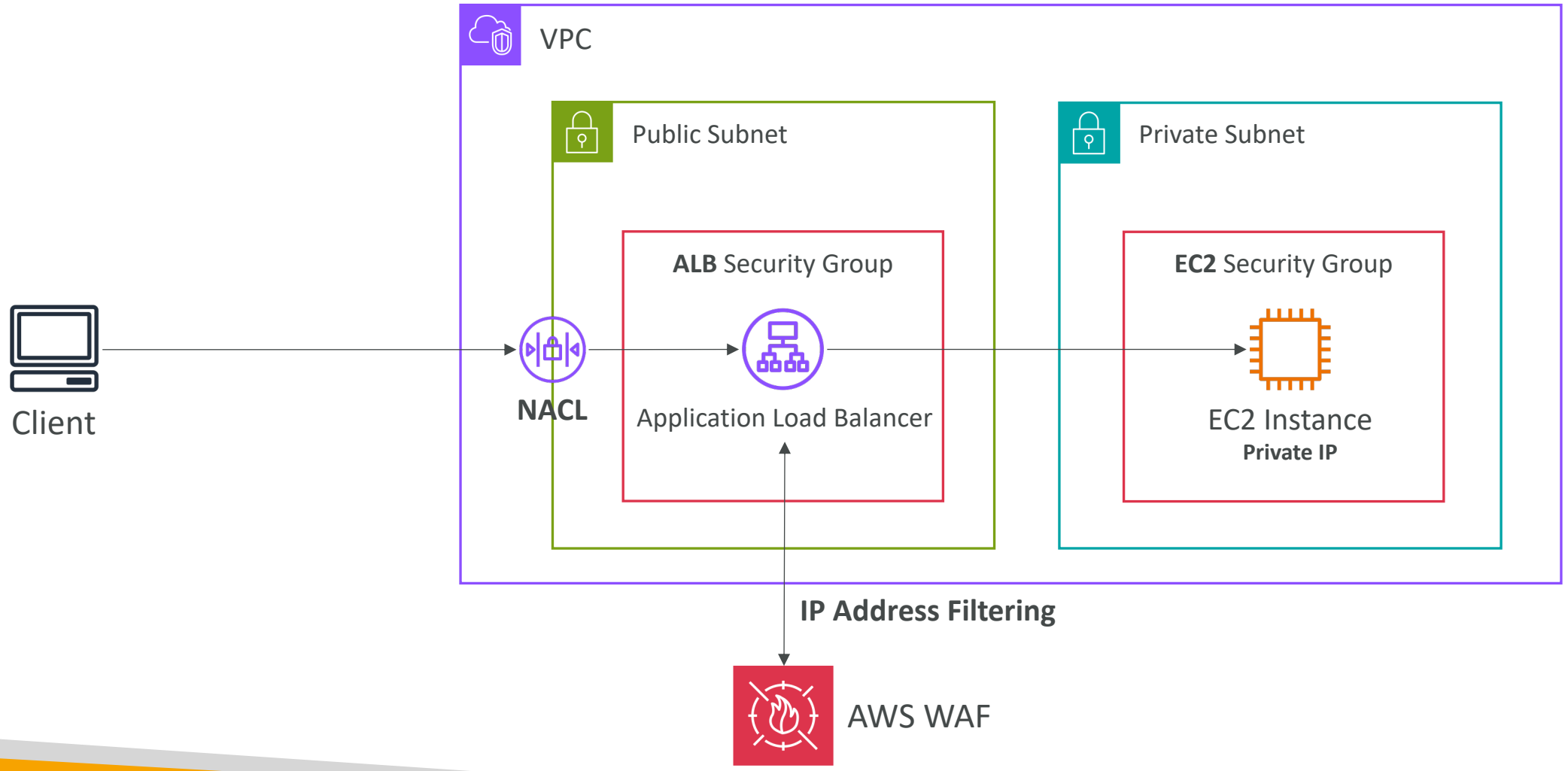
Blocking an IP address – with an NLB



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

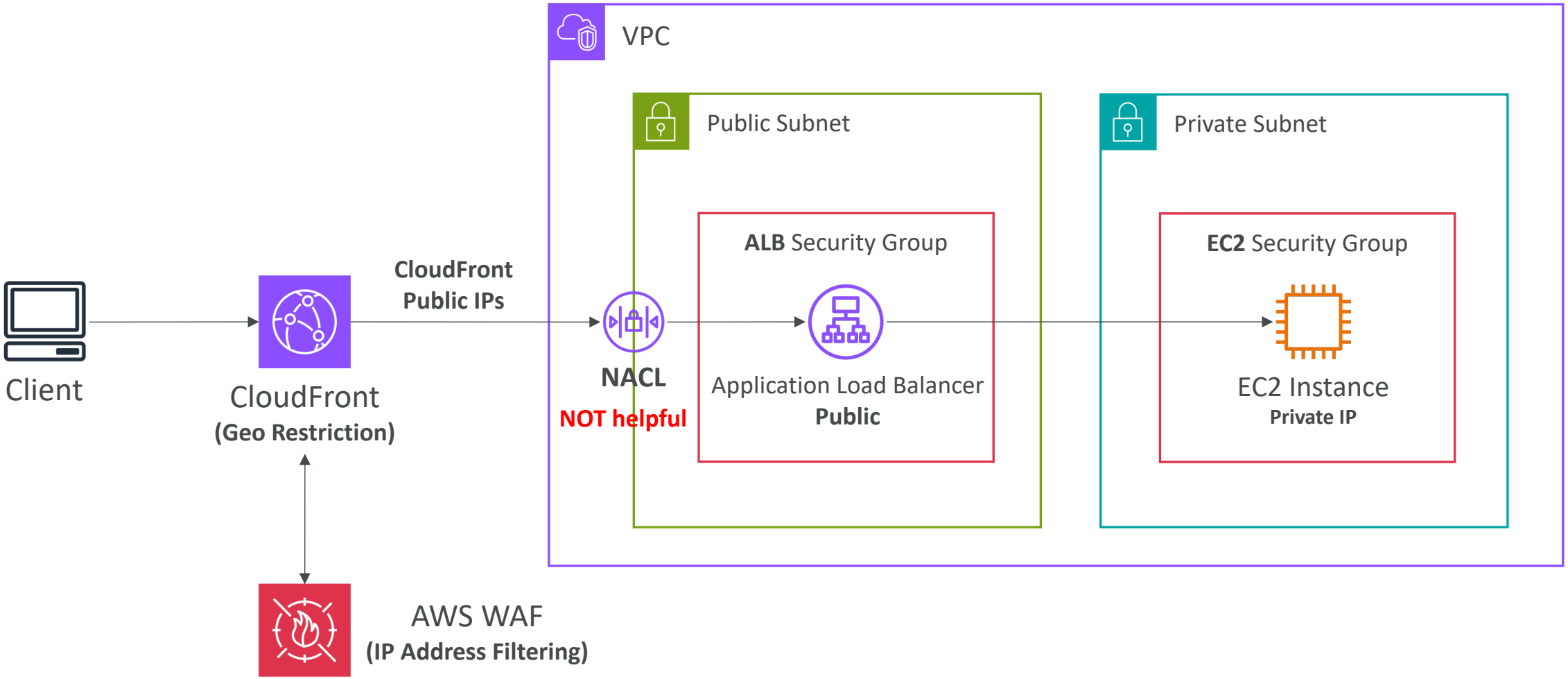
Blocking an IP address – ALB + WAF



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Blocking an IP address – ALB, CloudFront & WAF



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Amazon Inspector

- Automated Security Assessments

- For EC2 instances
  - Leveraging the AWS System Manager (SSM) agent
  - Analyze against unintended network accessibility
  - Analyze the running OS against known vulnerabilities
- For Container Images push to Amazon ECR
  - Assessment of Container Images as they are pushed
- For Lambda Functions
  - Identifies software vulnerabilities in function code and package dependencies
  - Assessment of functions as they are deployed

- Reporting & integration with AWS Security Hub
- Send findings to Amazon Event Bridge



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

What does Amazon Inspector evaluate?

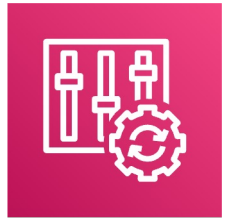


- **Remember: only for EC2 instances, Container Images & Lambda functions**
- Continuous scanning of the infrastructure, only when needed
- Package vulnerabilities (EC2, ECR & Lambda) – database of CVE
- Network reachability (EC2)
- A risk score is associated with all vulnerabilities for prioritization

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Config



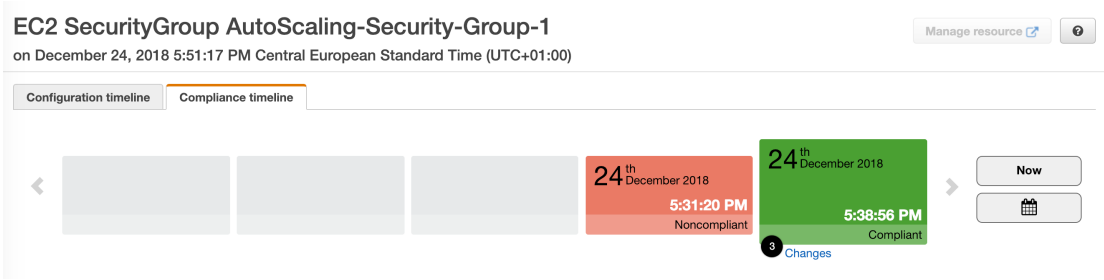
- Helps with auditing and recording **compliance** of your AWS resources
- Helps record configurations and changes over time
- **AWS Config Rules does not prevent actions from happening (no deny)**
- Questions that can be solved by AWS Config:
  - Is there unrestricted SSH access to my security groups?
  - Do my buckets have any public access?
  - How has my ALB configuration changed over time?
- You can receive alerts (SNS notifications) for any changes
- AWS Config is a per-region service
- Can be aggregated across regions and accounts

© Stephane Maarek

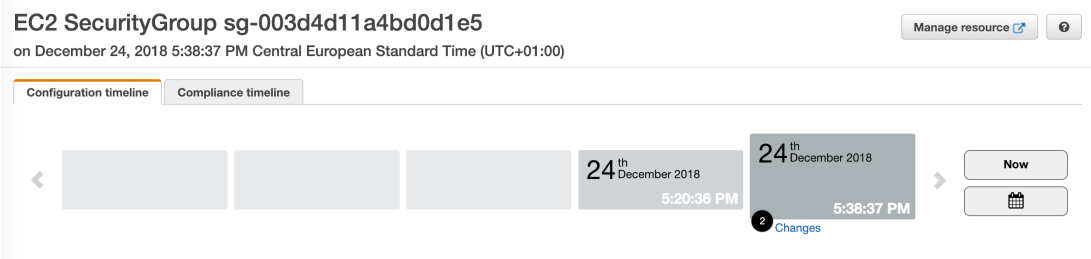
NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Config Resource

- View compliance of a resource over time



- View configuration of a resource over time



- View CloudTrail API calls if enabled

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Config Rules

- Can use AWS managed config rules (over 75)
- Can make custom config rules (must be defined in AWS Lambda)
  - Evaluate if each EBS disk is of type gp2
  - Evaluate if each EC2 instance is t2.micro
- Rules can be evaluated / triggered:
  - For each config change
  - And / or: at regular time intervals
- Trigger Amazon EventBridge if the rule is non-compliant (chain with Lambda)
- Rules can have auto remediations through **SSM Automations**
  - If a resource is not compliant, you can trigger an auto remediation
  - Ex: remediate security group rules, stop instances with non-approved tags

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Managed Logs

- Load Balancer Access Logs (ALB, NLB, CLB) => to S3
  - Access logs for your Load Balancers
- CloudTrail Logs => to S3 and CloudWatch Logs
  - Logs for API calls made within your account
- VPC Flow Logs => to S3, CloudWatch Logs, Kinesis Data Firehose
  - Information about IP traffic going to and from network interfaces in your VPC
- Route 53 Access Logs => to CloudWatch Logs
  - Log information about the queries that Route 53 receives
- S3 Access Logs => to S3
  - Server access logging provides detailed records for the requests that are made to a bucket
- CloudFront Access Logs => to S3
  - Detailed information about every user request that CloudFront receives
- AWS Config => to S3

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Amazon GuardDuty

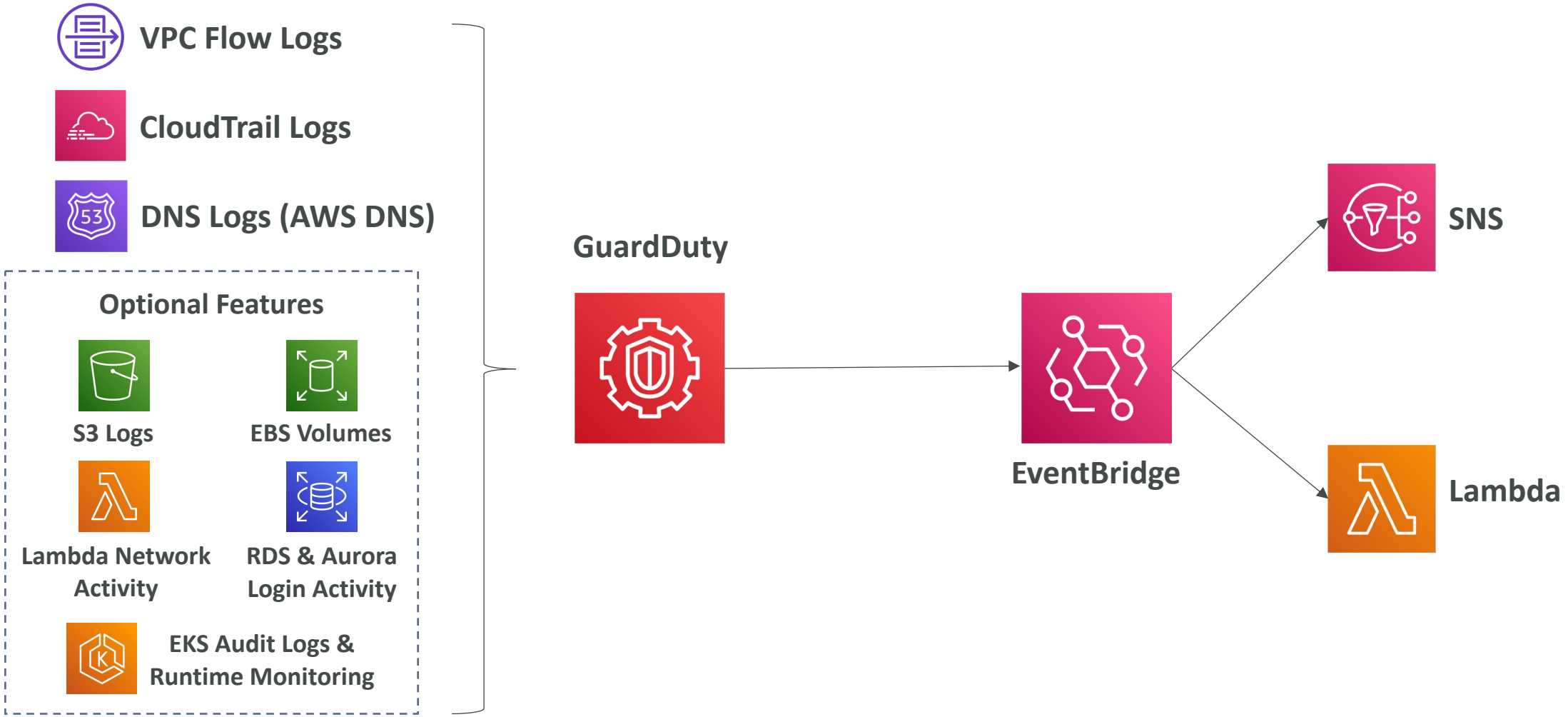


- Intelligent Threat discovery to protect your AWS Account
- Uses Machine Learning algorithms, anomaly detection, 3rd party data
- One click to enable (30 days trial), no need to install software
- Input data includes:
  - **CloudTrail Events Logs** – unusual API calls, unauthorized deployments
    - **CloudTrail Management Events** – create VPC subnet, create trail, …
    - **CloudTrail S3 Data Events** – get object, list objects, delete object, …
  - **VPC Flow Logs** – unusual internal traffic, unusual IP address
  - **DNS Logs** – compromised EC2 instances sending encoded data within DNS queries
  - **Optional Feature** – EKS Audit Logs, RDS & Aurora, EBS, Lambda, S3 Data Events…
- Can setup **EventBridge rules** to be notified in case of findings
- EventBridge rules can target AWS Lambda or SNS
- **Can protect against CryptoCurrency attacks (has a dedicated "finding" for it)**

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Amazon GuardDuty

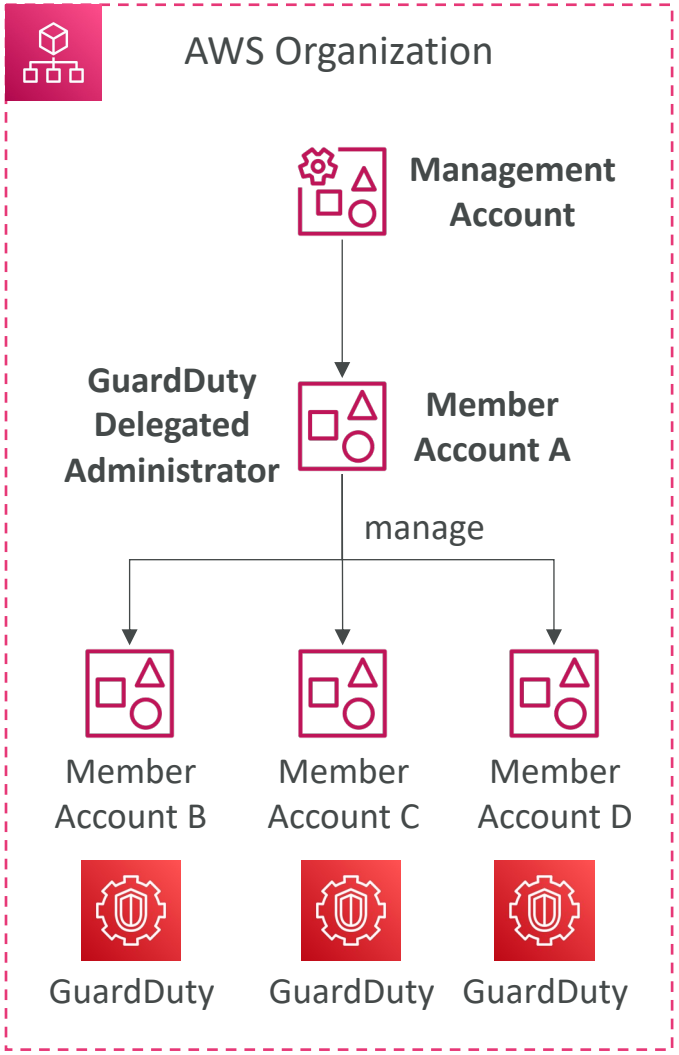


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

GuardDuty – Delegated Administrator

- AWS Organization member accounts can be designated to be a **GuardDuty Delegated Administrator**
- Have full permissions to enable and manage GuardDuty for all accounts in the Organization
- Can be done only using the Organization Management Account



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Conditions

aws:SourceIp
restrict the client IP **from**
which the API calls are being made

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Deny",
            "Action": "*",
            "Resource": "*",
            "Condition": {
                "NotIpAddress": {
                    "aws:SourceIp": ["192.0.2.0/24", "203.0.113.0/2
                }
            }
        }
    ]
}
```

aws:RequestedRegion
restrict the region the
API calls are made **to**

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Deny",
            "Action": ["ec2:*", "rds:*", "dynamodb:*"],
            "Resource": "*",
            "Condition": {
                "StringEquals": {
                    "aws:RequestedRegion": ["eu-central-1", "eu-west-1"]
                }
            }
        }
    ]
}
```

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

IAM Conditions

ec2:ResourceTag
restrict based on **tags**

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": ["ec2:startInstances", "ec2:StopInstances"],
            "Resource": "arn:aws:ec2:us-east-1:123456789012:instance/*",
            "Condition": {
                "StringEquals": {
                    "ec2:ResourceTag/Project": "DataAnalytics",
                    "aws:PrincipalTag/Department": "Data"
                }
            }
        }
    ]
}
```

aws:MultiFactorAuthPresent
to force **MFA**

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": "ec2:*",
            "Resource": "*"
        },
        {
            "Effect": "Deny",
            "Action": ["ec2:StopInstances", "ec2:TerminateInstances"],
            "Resource": "*",
            "Condition": {
                "BoolIfExists": {
                    "aws:MultiFactorAuthPresent": false
                }
            }
        }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM for S3

- s3:ListBucket permission applies to
  arn:aws:s3:::test
- => bucket level permission

- s3:GetObject, s3:PutObject, s3:DeleteObject applies to
  arn:awn:s3:::test/*
- => object level permission

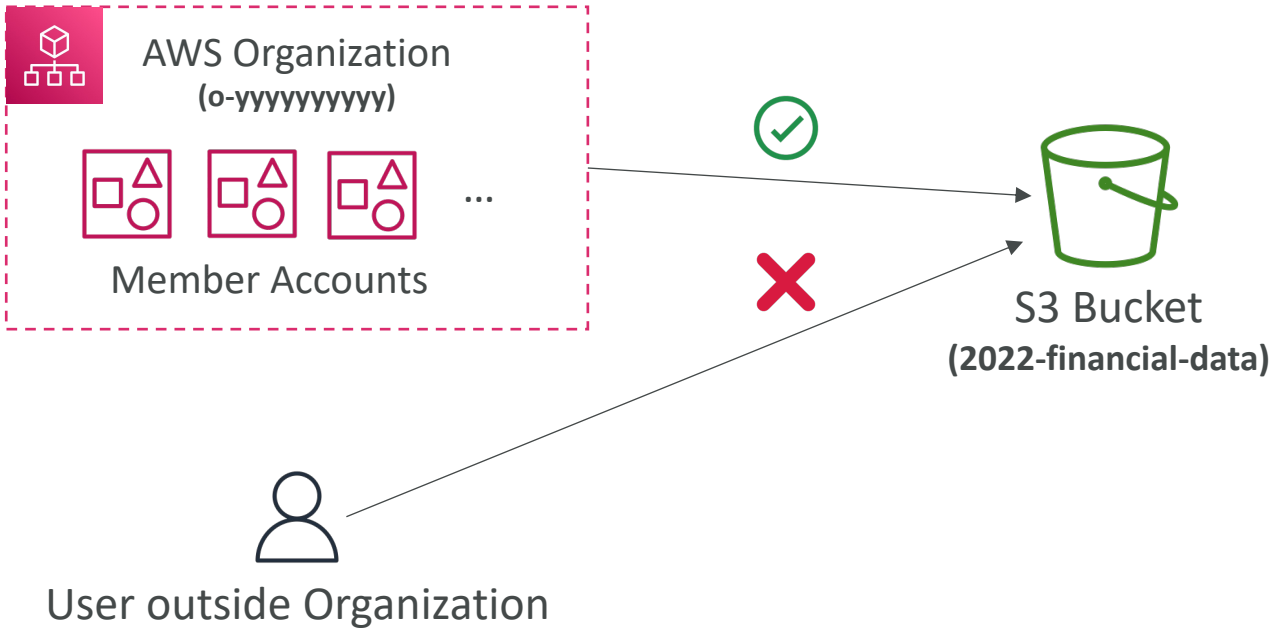
```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": ["s3:ListBucket"],
            "Resource": "arn:aws:s3:::test"
        },
        {
            "Effect": "Allow",
            "Action": [
                "s3:PutObject",
                "s3:GetObject",
                "s3:DeleteObject"
            ],
            "Resource": "arn:aws:s3:::test/*"
        }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Resource Policies & aws:PrincipalOrgID

- **aws:PrincipalOrgID** can be used in any resource policies to restrict access to accounts that are member of an AWS Organization

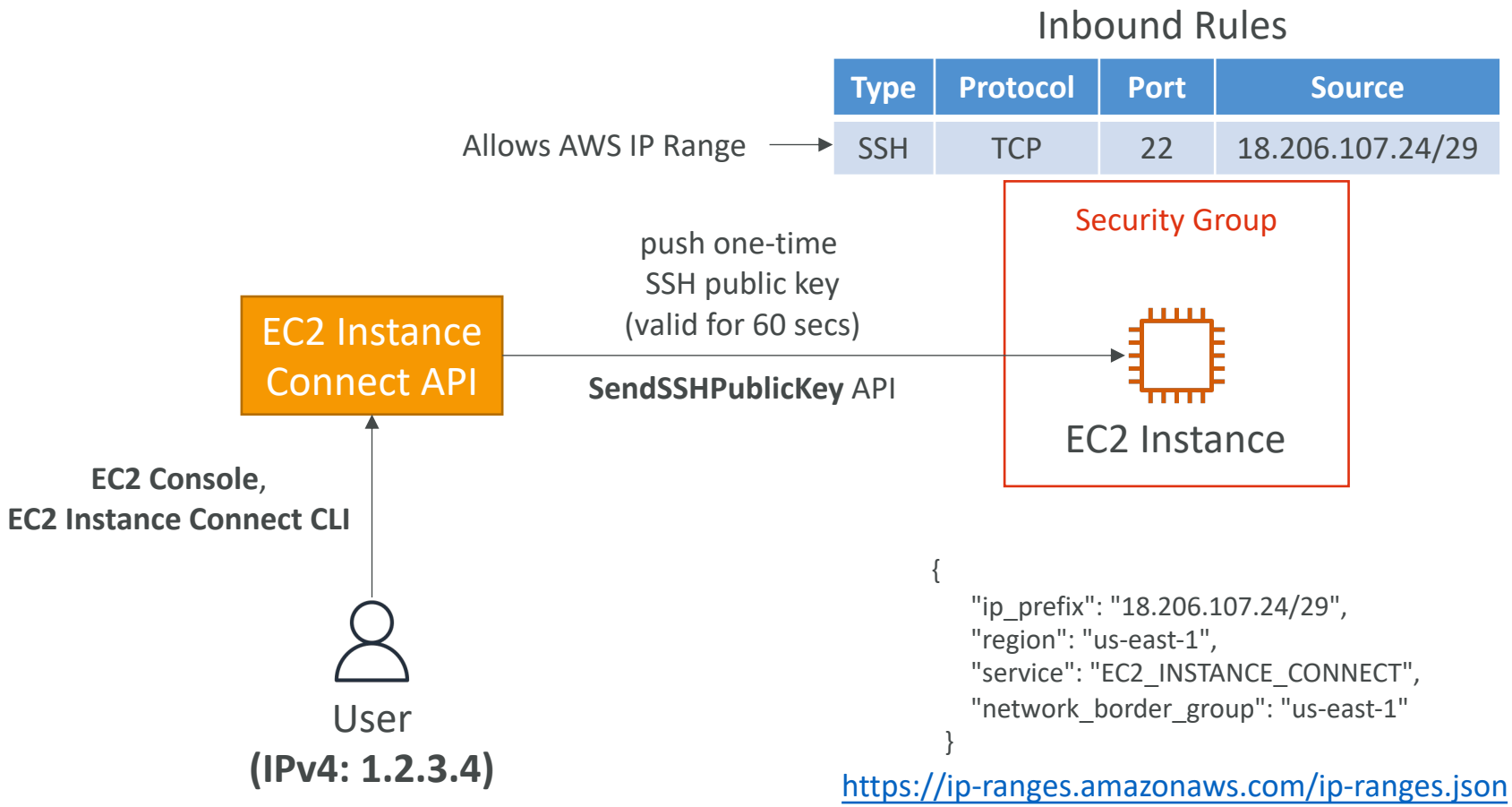



```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": ["s3:PutObject", "s3:GetObject"],
            "Resource": "arn:aws:s3:::2022-financial-data/*",
            "Condition": {
                "StringEquals": {
                    "aws:PrincipalOrgID": ["o-yyyyyyyyyy"]
                }
            }
        }
    ]
}
```

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

EC2 Instance Connect (SendSSHPublicKey API)



Note: All connections are logged in CloudTrail

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Security Hub

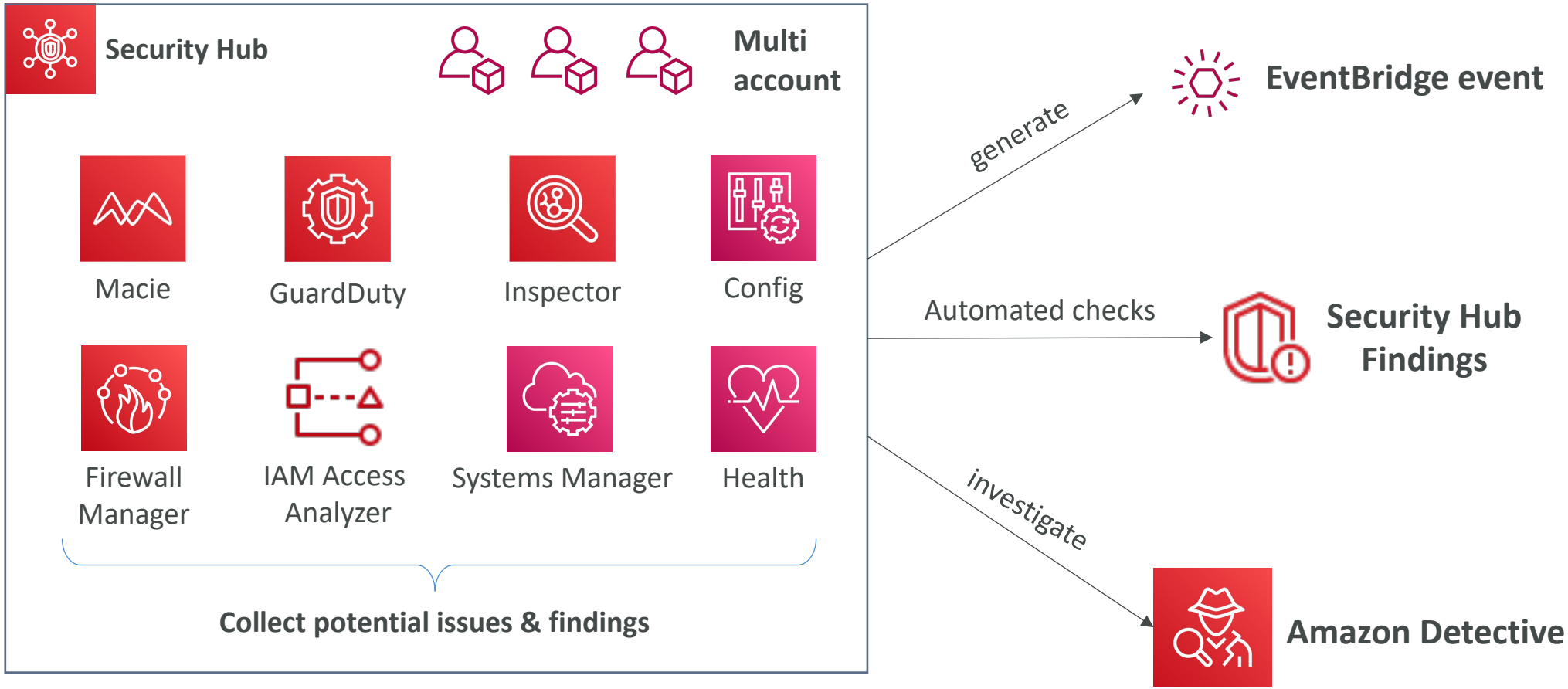


- **Central security tool** to manage security **across several AWS accounts** and **automate security checks**
- Integrated dashboards showing current security and compliance status to quickly take actions
- Automatically aggregates alerts in predefined or personal findings formats from various AWS services & AWS partner tools:
  - Config
  - GuardDuty
  - Inspector
  - Macie
  - IAM Access Analyzer
  - AWS Systems Manager
  - AWS Firewall Manager
  - AWS Health
  - AWS Partner Network Solutions
- Must first enable the AWS Config Service

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Security Hub



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Amazon Detective



- GuardDuty, Macie, and Security Hub are used to identify potential security issues, or findings
- Sometimes security findings require deeper analysis to isolate the root cause and take action – it's a complex process
- Amazon Detective **analyzes, investigates, and quickly identifies the root cause of security issues or suspicious activities (using ML and graphs)**
- **Automatically collects and processes events** from VPC Flow Logs, CloudTrail, GuardDuty and create a unified view
- Produces visualizations with details and context to get to the root cause

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com